

PROJECT BLUEPRINT

UK Local Grocery Store

A comprehensive project blueprint for building a hyperlocal grocery delivery platform, covering system architecture, database design, API specification, UK compliance, and an 8-week development plan.

May 2026

Version 2.0

Prepared by Z.ai

Table of Contents

1. System Architecture	4
1.1 System Architecture Flow	4
1.2 Technology Stack	4
2. Order Lifecycle	5
3. Authentication and Role-Based Access	7
4. Database Schema	8
4.1 Core Tables	8
4.2 Supporting Tables	11
4.3 VAT Configuration	12
5. UI/UX Blueprint	13
5.1 Storefront Layout	13
5.2 Responsive Design Breakpoints	15
5.3 Accessibility Requirements (WCAG 2.1 AA)	15
5.4 Error and Loading States	16
6. API Design	17
6.1 Public Endpoints (Storefront)	17
6.2 Admin Endpoints	17
6.3 Security Requirements	18
7. Order Management (Kanban Board)	19
8. Admin Dashboard	20
8.1 Dashboard Overview	20
8.2 Catalog (Product Settings)	20
8.3 Finance	21
8.4 User/Employee Management	21
8.5 Marketing and CMS	21
8.6 System Settings	22

9. Order Tracking and Delivery ETA	22
9.1 Tracking Flow Overview	22
9.2 Phase 1: Rider Dispatch	23
9.3 Phase 2: Manual ETA Setting	24
9.4 Phase 3: Live Customer Tracking	25
9.5 Phase 4: ETA Adjustments and Edge Cases	26
9.6 Order Tracking API Endpoints	27
9.7 Tracking Database Fields	27
10. Mobile Application (Customer Only)	28
10.1 Customer Mobile App	29
10.2 Staff Access via Responsive Website	32
10.3 Technical Architecture	34
10.4 CapacitorJS Configuration (Customer App Only)	35
10.5 App Store Submission Requirements	35
10.6 Offline Support and Performance	36
11. UK Laws, Regulations, and Compliance	37
11.1 UK GDPR and Data Protection Act 2018	37
11.2 Consumer Rights Act 2015	40
11.3 Consumer Contracts (Information, Cancellation and Additional Charges) Regulations 2013	42
11.4 Food Information Regulations 2014 (FIC) and Natasha's Law	44
11.5 Challenge 25, Licensing Act 2003, and Age Verification .	46
11.6 Equality Act 2010 and Accessibility	48
11.7 VAT Act 1994 and HMRC Compliance	49
11.8 Electronic Commerce Regulations 2002	51
11.9 Payment Services Regulations 2017 and Strong Customer Authentication	53
11.10 Food Safety Act 1990 and Food Hygiene Regulations 2006.	

11.11 Consumer Protection from Unfair Trading Regulations 2008	56
11.12 Privacy and Electronic Communications Regulations (PECR)	57
11.13 Weights and Measures Act 1985 and Unit Pricing . . .	59
11.14 Digital Markets, Competition and Consumers Act 2024	60
11.15 Compliance Implementation Summary	62
12. Development Plan	64
12.1 Phase Details	64
12.2 Phase 1: Foundation (Week 1)	65
12.3 Phase 2: Core Storefront (Weeks 2-3)	66
12.4 Phase 3: Admin Dashboard (Week 4)	66
12.5 Phase 4: Payments and Webhooks (Week 5)	67
12.6 Phase 5: Compliance Layer (Week 6)	67
12.7 Phase 6: Notifications (Week 7)	67
12.8 Phase 7: Testing and QA (Week 8)	68
12.9 Phase 8: Launch (Week 9+)	68
13. Notification System	68
14. Security Framework	70
14.1 Data Protection	70
14.2 Infrastructure Security	70
14.3 Incident Response	70
15. Golden Rules	71
16. Final Checklist	72
17. Cost Estimation	74
17.1 Development Costs (One-Time)	74
17.2 Monthly Operational Costs	75

1. System Architecture

This blueprint defines a hyperlocal grocery delivery platform built for the UK market. The system follows a server-first architecture where the backend (Next.js API Routes on Vercel) is the single source of truth for all pricing, inventory, and order state. Stripe handles payment processing via webhooks, ensuring that no order is marked as paid without cryptographic verification. The Turso database provides edge-replicated SQLite for fast reads, and a Turborepo monorepo houses both the customer storefront and the admin dashboard in a single repository.

1.1 System Architecture Flow

The diagram below illustrates the complete data flow from customer browsing through to order completion. Every arrow represents a server-to-server communication or a verified webhook, ensuring that no client-side action can bypass validation or alter prices.

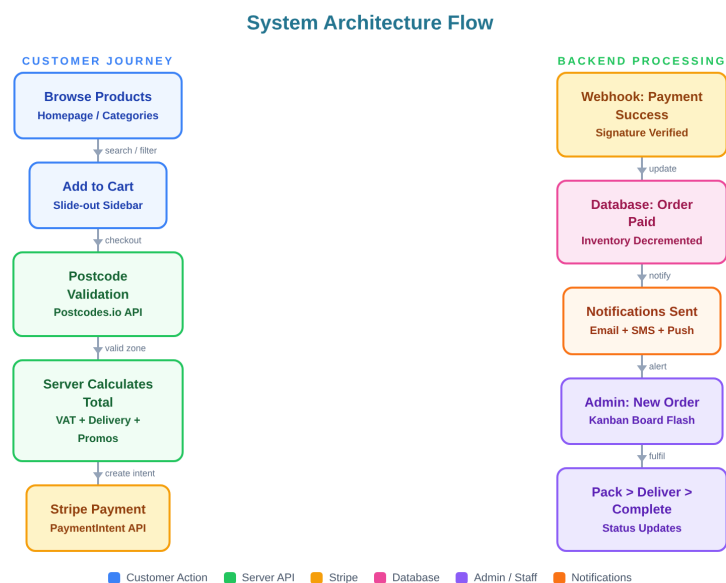


Figure 1: System architecture flow - Customer journey (left) and backend processing (right)

1.2 Technology Stack

Layer	Technology	Purpose	Cost Tier
-------	------------	---------	-----------

Frontend	Next.js 14+ (App Router)	Storefront + Admin (Turborepo monorepo)	Free
Backend API	Next.js API Routes	REST endpoints on Vercel serverless	Free tier
Database	Turso (libSQL)	Primary data store with edge replication	Free tier
Cache	Vercel KV (Redis)	Session storage, rate limiting, cart cache	Free tier
Auth	NextAuth.js v5	Authentication with UK provider support	Free
Payments	Stripe	Card payments, refunds, webhook events	1.5% + 20p per tx
File Storage	Vercel Blob	Product images, receipts	Free tier
Notifications	Resend + Twilio	Email receipts + SMS delivery updates	Pay as you go
Maps/Geocoding	Postcodes.io API	UK postcode validation and geolocation	Free
Monitoring	Sentry	Error tracking and performance monitoring	Free tier
CI/CD	GitHub Actions	Automated testing and deployment	Free tier
Mobile	CapacitorJS	Wrap web app for iOS/Android	Free

Table 1: Complete technology stack with cost tiers

2. Order Lifecycle

The order lifecycle is the most critical flow in the system. Every step must be atomic and idempotent: if a webhook is delivered twice, the system must not create duplicate orders or decrement inventory twice. The diagram below shows both the success path (left) and the failure path (right), along with the automatic recovery mechanisms for each scenario.

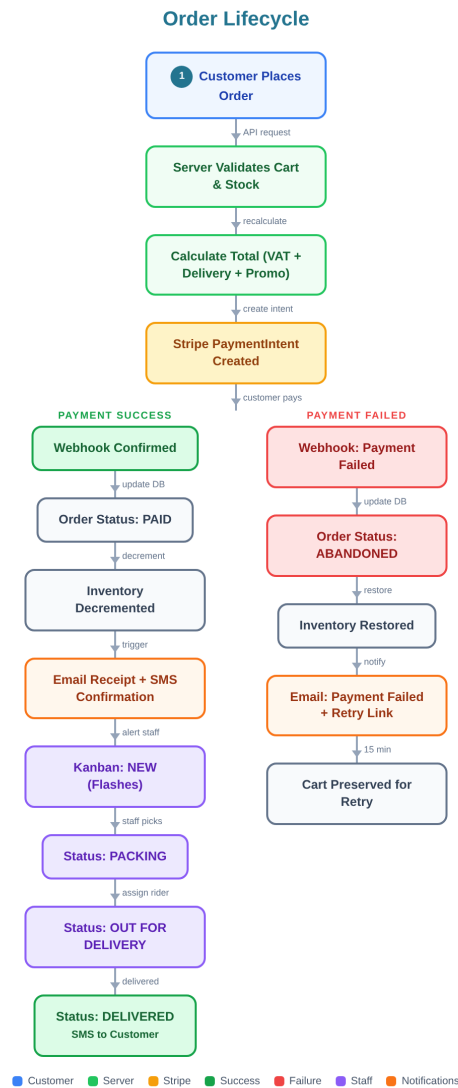


Figure 2: Order lifecycle - Success path (left) and failure recovery (right)

On the success path, once Stripe confirms payment via webhook, the server updates the order status to "Paid", decrements the inventory count for each item, and triggers notifications to both the customer (email receipt) and the admin dashboard (Kanban flash). On the failure path, the order is marked "Abandoned", inventory is restored, and the customer receives an email with a retry link. The cart is preserved for 15 minutes to allow the customer to attempt payment again.

3. Authentication and Role-Based Access

The platform uses a dual authentication strategy: passwordless magic-link login for customers (maximising conversion rates) and email-plus-password with optional two-factor authentication for staff. All sessions are managed via HTTP-only cookies to prevent XSS-based session theft. Staff sessions expire after 30 minutes of inactivity, while customer sessions last 7 days.



Figure 3: Authentication flows (Customer and Staff) with RBAC permission matrix

The RBAC matrix ensures that each staff role can only access the features relevant to their job. Pickers see only the packing queue; riders see only the delivery queue with map and customer phone number. Managers can manage products, categories, banners, and promo codes, but cannot access system settings or staff salary data. Only the Owner has unrestricted access to all dashboard features including finance reports, audit logs, and system configuration.

4. Database Schema

The database schema is designed for Turso (SQLite) with full UK compliance support built in. Every product record includes VAT rate, unit pricing string, allergen data, and Challenge 25 flag. Order items snapshot the price and VAT rate at the time of purchase to ensure accurate historical records even if product prices change later. All tables use UUID v4 primary keys.

4.1 Core Tables

users

Column	Type	Constraints	Purpose
id	TEXT	PRIMARY KEY	UUID v4 unique identifier
email	TEXT	UNIQUE, NOT NULL	Login and communication
phone	TEXT		Delivery contact number
full_name	TEXT	NOT NULL	Customer display name
password_hash	TEXT		bcrypt hash (staff only)
role	TEXT	DEFAULT "customer"	customer/owner/manager/picker/rid er
postcode	TEXT		Default delivery postcode
is_banned	BOOLEAN	DEFAULT FALSE	Fraud prevention flag
created_at	TEXT	DEFAULT CURRENT_TIMESTAMP	Account creation date
updated_at	TEXT		Last profile update

Table 2: Users table schema

products

Column	Type	Constraints	Purpose
id	TEXT	PRIMARY KEY	UUID v4 unique identifier
name	TEXT	NOT NULL	Product display name

description	TEXT		Full product description
category_id	TEXT	FK -> categories.id	Product category
brand_id	TEXT	FK -> brands.id	Product brand
price	REAL	NOT NULL	Selling price in GBP
compare_at_price	REAL		Original price (for discount display)
unit_price	TEXT	NOT NULL	e.g. "1.20/100g" (UK law requirement)
vat_rate	REAL	NOT NULL	0.0, 0.05, or 0.20
weight_value	REAL		Numeric weight or volume
weight_unit	TEXT		g, kg, ml, L, etc.
image_url	TEXT		Product photograph URL
stock_count	INTEGER	DEFAULT 0	Current inventory level
low_stock_threshold	INTEGER	DEFAULT 10	Alert trigger level
is_active	BOOLEAN	DEFAULT TRUE	Kill switch for stock-out
challenge_25	BOOLEAN	DEFAULT FALSE	Age-restricted item flag
allergens	TEXT		Comma-separated allergen list
ingredients	TEXT		Full ingredients list
use_by_date	TEXT		For fresh items
created_at	TEXT	DEFAULT CURRENT_TIMESTAMP	Product creation date

Table 3: Products table schema

orders

Column	Type	Constraints	Purpose
id	TEXT	PRIMARY KEY	UUID v4 unique identifier

user_id	TEXT	FK -> users.id	Customer reference
status	TEXT	NOT NULL	new/packing/out_for_delivery/delivered/cancelled
subtotal	REAL	NOT NULL	Pre-VAT item total
vat_total	REAL	NOT NULL	Total VAT collected
delivery_fee	REAL	DEFAULT 0	Delivery charge
discount_amount	REAL	DEFAULT 0	Promo code discount
total	REAL	NOT NULL	Final amount charged
stripe_payment_intent_id	TEXT	UNIQUE	Stripe payment reference
delivery_address	TEXT	NOT NULL	Full delivery address
delivery_postcode	TEXT	NOT NULL	UK postcode
customer_phone	TEXT		Contact number for delivery
assigned_picker_id	TEXT	FK -> users.id	Staff packing the order
assigned_rider_id	TEXT	FK -> users.id	Staff delivering the order
estimated_delivery_minutes	INTEGER		ETA set manually by rider (e.g., 45)
estimated_delivery_at	TEXT		Calculated: dispatched_at + ETA minutes
dispatched_at	TEXT		Timestamp when rider starts delivery
delivered_at	TEXT		Timestamp when rider confirms delivery
eta_adjustment_count	INTEGER	DEFAULT 0	Number of ETA adjustments (max 3)
age_verified	BOOLEAN	DEFAULT FALSE	Whether Challenge 25 check passed
promo_code_id	TEXT	FK -> promo_codes.id	Applied discount code

cancellation_reason	TEXT		If cancelled, record reason
created_at	TEXT	DEFAULT CURRENT_TIMESTAMP	Order timestamp
updated_at	TEXT		Last status change

Table 4: Orders table schema

order_items

Column	Type	Constraints	Purpose
id	TEXT	PRIMARY KEY	UUID v4
order_id	TEXT	FK -> orders.id	Parent order
product_id	TEXT	FK -> products.id	Product at time of order
quantity	INTEGER	NOT NULL	Number of items
unit_price	REAL	NOT NULL	Price per item (snapshot)
vat_rate	REAL	NOT NULL	VAT rate at time of order (snapshot)
line_total	REAL	NOT NULL	unit_price * quantity

Table 5: Order items table schema

4.2 Supporting Tables

Table	Key Columns	Purpose
categories	id, name, slug, display_order, is_active	Product categorisation (e.g. Dairy, Meat, Bakery)
brands	id, name, slug, logo_url	Brand filtering and display
promo_codes	id, code, discount_type, discount_value, min_order, max_uses, used_count, expires_at	Marketing promotions
delivery_zones	id, postcode_prefix, max_distance_km, is_active	Delivery area management

banners	id, image_url, link_target, display_order, is_active	Homepage banner carousel
staff_attendance	id, user_id, date, status	Daily attendance tracking
wastage_log	id, product_id, quantity, reason, logged_at	Expired/damaged stock tracking
audit_log	id, user_id, action, entity, entity_id, timestamp	Security and compliance audit trail
order_tracking	id, order_id, status, eta_minutes, rider_lat, rider_lng, timestamp	Real-time tracking event log for customer order tracking
notifications	id, user_id, type, message, is_read, created_at	In-app and push notification queue

Table 6: Supporting tables overview

4.3 VAT Configuration

VAT handling in the UK is nuanced and must be precisely configured. Different categories of goods attract different rates, and errors in VAT calculation can result in HMRC penalties. Most grocery items are zero-rated, but alcohol, soft drinks, confectionery, and tobacco attract the standard 20% rate.

Category	VAT Rate	Examples	Notes
Zero-rated	0%	Most food, books, children's clothing	Most groceries are zero-rated
Reduced rate	5%	Domestic energy, children's car seats	Rarely applies to groceries
Standard rate	20%	Alcohol, soft drinks, confectionery, tobacco	Applies to "luxury" food items

Table 7: UK VAT rate configuration by category

Critical Rule: Always calculate VAT on the server side. Never trust client-side price calculations. The API must recalculate the total from product IDs and quantities stored in the database, not from prices sent by the client.

5. UI/UX Blueprint

The storefront UI is designed mobile-first with a scroll-based layout that mirrors the natural customer journey: discover products, add to cart, checkout, and receive delivery updates. Every component meets WCAG 2.1 AA accessibility standards and displays UK-compliant pricing information including unit pricing, VAT breakdown, and Challenge 25 age verification badges.

5.1 Storefront Layout

Sticky Header Section

- **Postcode / Location Picker (Top Left):** GPS locator or text field showing the customer's UK postcode (e.g., "Delivering to SW1A"). Validates against delivery zones via Postcodes.io.
- **High-Speed Delivery Timer (Next to Location):** Bold, bright text showing exact delivery speed (e.g., "Delivering in 15 Mins" or "Get it by 4:30 PM"). Builds instant trust so the customer does not leave for a competitor.
- **Live Predictive Search Bar (Center Focus):** Large search field with animated typing placeholder. Typing "C" instantly suggests "Cheddar Cheese" or "Cadbury" in milliseconds. Most users want to search, not browse.
- **Floating Cart Widget Button (Top Right):** Bright green action badge displaying current item count and price (e.g., "3 Items | 14.20 GBP"). Tapping opens a quick slide-out sidebar checkout window instantly.

Homepage Components

- **Auto-Scroll Banner Carousel:** 4 configurable banners in a continuous sliding loop, each linking to a category or promotion. 3-second auto-rotation.
- **Category Product Sliders:** Each row has a bold category name on the left and a "See All" link on the right. Products displayed as cards with: product image on white background, prominent "ADD" button overlay, discount badge (e.g., "22% OFF"), bold active price with crossed-out original, product title with weight/volume, and star rating tag.
- **Homepage Grid:** Approximately 10-15 distinct categories, each in a 4x4 product grid format. Admin can change or add categories from the dashboard.

Category Listing Page

- **Left Sidebar:** Narrow, vertical scrolling menu listing all sub-categories. Active item turns bright with a side accent bar. Clicking another sub-category instantly changes the right grid without page reload.
- **Right Side Product Grid:** Clean 6x3 grid displaying product cards with white-background photo, bold "ADD" button, live pricing, weight, and star rating.

Product Detail Page

- **Top Section:** Thumbnail gallery (far left), main high-resolution image (center), and product details on the right including bold title, brand link, quantity indicator, price badge, coupons and offers list, and trust badges (Easy Refunds, Fast Delivery). Wide solid "Add To Cart" button under the image.
- **Bottom Section (Cross-Selling):** "Similar Products" row showing alternative brands/versions, and "You Might Also Like" row showing complementary items to increase basket value.

Slide-Out Cart Sidebar

- **Top:** Back arrow, green bar showing instant savings, coupons tab for one-tap promo code application.
- **Items List:** Delivery timer, product rows with photo/title/price, counter buttons (- 1 +), "Add More" shortcut.
- **Bill Summary:** Item total, delivery fee (with free shipping goal line), and bold final total.
- **Checkout Button:** Massive, fixed pink "Proceed to Pay" button at bottom launching Stripe card window.

Customer Entry Popup

- Upon accessing the app, a prompt automatically requests geographic data for delivery validation.
- Postcode outside the delivery zone shows "Sorry, we do not deliver to your area yet" with an email signup option for future expansion notifications.
- Guest checkout available with email-only identification; full account creation prompted post-purchase.

Footer Section

- **Top Row: "How it Works" - 3 white boxes explaining: Browse products, Place order, Get free delivery.**
- **Middle Row: Categories links grid in 5 columns for SEO and quick navigation.**
- **Bottom Row: Brand logo and social icons, company links (Home, Delivery Areas, Careers, Support, Blog), legal links (Privacy Policy, Terms of Use), and app store download buttons.**

5.2 Responsive Design Breakpoints

Breakpoint	Width	Target Devices	Layout Changes
Mobile S	320-374px	iPhone SE, small Android	Single column, bottom sheet cart, hamburger nav
Mobile	375-428px	iPhone 14/15, Pixel	Single column, sticky add button, swipe cards
Tablet	429-768px	iPad Mini, Android tablets	Two-column product grid, sidebar cart
Desktop S	769-1024px	Small laptops	Three-column grid, expanded nav, sidebar categories
Desktop	1025-1440px	Standard monitors	Four-column grid, full navigation bar
Desktop XL	1441px+	Large monitors	Six-column grid, wider spacing

Table 8: Responsive design breakpoints

5.3 Accessibility Requirements (WCAG 2.1 AA)

Component	Requirement	Implementation
Product images	Alt text describing product	Alt attribute populated from product name + weight
Buttons	Minimum 44x44px tap target	CSS min-width/min-height; no tiny icon-only buttons
Colour contrast	4.5:1 for normal text, 3:1 for large text	All text/background pairs tested with contrast checker

Form labels	Every input has visible label	Label element + for/id association; no placeholder-only labels
Keyboard nav	All interactive elements focusable	Tab order logical; focus indicators visible; skip-to-content link
Screen reader	Dynamic content announced	aria-live regions for cart updates, order status changes
Text resize	Up to 200% without horizontal scroll	Use rem units; test at browser zoom 200%
Error messages	Descriptive, not just "Error"	Specific message + suggestion; aria-describedby on input

Table 9: Accessibility requirements by component

5.4 Error and Loading States

State	Trigger	User Experience	Technical Action
Loading	Data fetch in progress	Skeleton placeholders matching content layout	Show within 200ms; cancel on unmount
Empty	No products in category	Friendly illustration + "No items yet" message	Suggest alternative categories
Error (4xx)	Invalid input, auth failure	Inline error near relevant field	Log event; show recovery options
Error (5xx)	Server crash, DB timeout	Full-page error with retry button	Alert Sentry; exponential backoff retry
Offline	No internet connection	Banner + cached content where possible	Service Worker stale-while-revalidate
Payment fail	Card declined, Stripe error	Clear message + alternative payment prompt	Do NOT create order; keep cart intact
Out of stock	Item becomes unavailable	Badge on product card; disable add button	Polling update every 30s
Delivery u navailable	Postcode outside zone	Modal with explanation + email signup	Postcodes.io validation before cart

Table 10: Error and loading state specifications

6. API Design

All endpoints are implemented as Next.js API Routes running on Vercel serverless functions. Every endpoint requires HTTPS. Public endpoints have rate limiting of 100 requests per minute per IP. Authenticated endpoints allow 300 requests per minute per user. All request bodies are validated using Zod schemas. SQL injection is prevented by using Drizzle ORM parameterised queries.

6.1 Public Endpoints (Storefront)

Method	Endpoint	Auth	Description
GET	/api/products?category=X&search=Y	No	List/search products with pagination
GET	/api/products/:id	No	Product detail with allergens and ingredients
GET	/api/categories	No	All active categories with product counts
POST	/api/auth/login	No	Magic link or credential login
POST	/api/auth/register	No	Customer registration
GET	/api/auth/session	Cookie	Current user session
POST	/api/delivery/validate-postcode	No	Check if postcode is in delivery zone
POST	/api/orders	Cookie	Create order from cart (server calculates total)
GET	/api/orders/:id	Cookie	Order status and details
POST	/api/payments/create-intent	Cookie	Create Stripe PaymentIntent server-side
POST	/api/payments/webhook	Stripe Sig	Handle Stripe events (payment_success, refund)

Table 11: Public API endpoints

6.2 Admin Endpoints

Method	Endpoint	Min Role	Description
GET	/api/admin/orders	Picker	Order list with status filters
PATCH	/api/admin/orders/:id/status	Picker	Update order status (Kanban)
GET/POST	/api/admin/products	Manager	List or create products
PATCH	/api/admin/products/:id	Manager	Update product details and stock
GET/POST	/api/admin/categories	Manager	Manage categories
GET/POST	/api/admin/promo-codes	Manager	Manage discount codes
GET	/api/admin/finance/summary	Owner	Revenue, profit, VAT collected
GET	/api/admin/staff	Manager	Staff list and performance
PATCH	/api/admin/staff/:id/attendance	Manager	Attendance toggle
GET/PUT	/api/admin/settings	Owner	Store settings (status, delivery zones)

Table 12: Admin API endpoints

6.3 Security Requirements

- **Rate limiting:** 100 req/min per IP (public), 300 req/min per user (authenticated)
- **Input validation:** Zod schemas for all request bodies; reject malformed data with 400 status
- **SQL injection prevention:** Drizzle ORM parameterised queries; never raw SQL strings
- **CSRF protection:** SameSite=Strict cookies for auth tokens; CSRF token for state-changing requests

- **Response headers: Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options on all responses**
- **CORS: Only allow requests from your own domain; no wildcard Access-Control-Allow-Origin**
- **Logging: All 4xx and 5xx responses logged to Sentry with request context**

7. Order Management (Kanban Board)

The admin dashboard uses a four-column Kanban board for order fulfilment. When a new paid order arrives via Stripe webhook, the "New" column flashes with an alert sound. Staff move orders through the pipeline by updating the status. Pickers see only the Packing column; Riders see only the Delivery column. Managers and Owners see all columns.

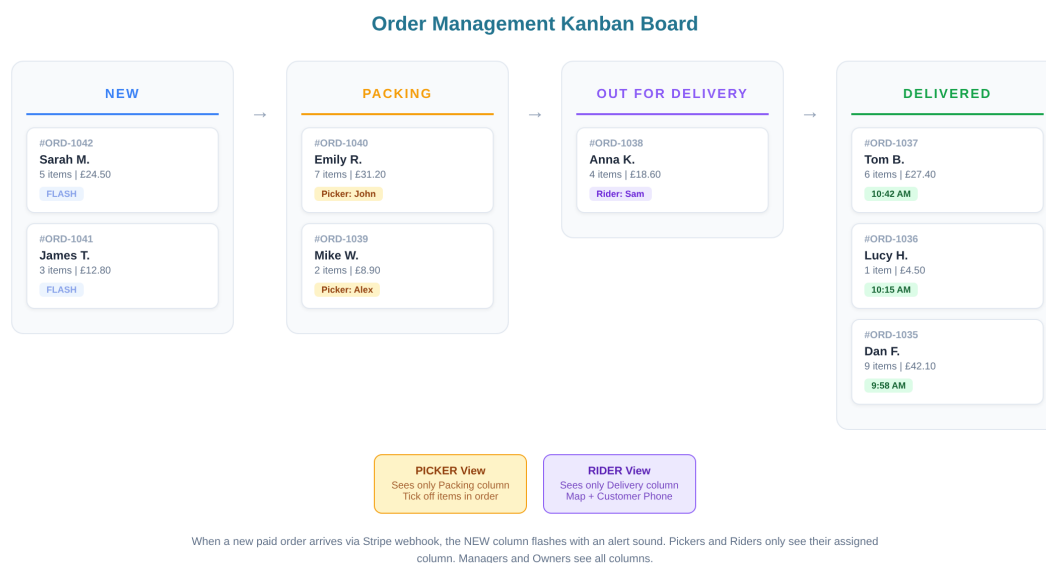


Figure 4: Kanban board layout with role-restricted views

Each order card displays the order ID, customer name, item count, and total bill. The "New" column cards flash to draw attention. When a Picker accepts an order, it moves to "Packing" with their name shown. Once packed, it moves to "Out for Delivery" where a Rider is assigned. On delivery confirmation, the order moves to "Delivered" with the completion timestamp.

8. Admin Dashboard

The admin dashboard is the operational nerve centre of the store. It provides real-time visibility into sales, inventory, orders, staff performance, and marketing campaigns. Access is controlled by the RBAC matrix defined in Section 3.

8.1 Dashboard Overview

Core Metric Cards (Live)

- **Gross Revenue:** Opens deep sub-ledger showing cash flow splits by payment method, time period, and category.
- **Net Profit Calculator:** Automatically deducts product cost, delivery fee margins, and taxes from gross revenue.
- **Total Orders Meter:** Counts successful checkouts; splits into Completed vs Active orders.
- **Date Filter:** Filter all metrics by day, week, month, or custom date range.

8.2 Catalog (Product Settings)

Add / Edit Product

- Name and description text fields
- Category dropdown (e.g., Dairy -> Milk)
- Drag-and-drop photo upload box
- Weight/size entry (Value + Unit dropdown: ml, g, kg, L)
- VAT selector (0%, 5%, 20%) for automatic billing calculations
- Challenge 25 toggle for age-restricted items
- Allergen text field (comma-separated) and ingredients text area

Stocks

- Stock count box for current available packets
- Low stock alert threshold (e.g., 10 triggers red warning highlights)
- Kill switch: fast on/off toggle to instantly show "Out of Stock" on customer app
- Out of stock / low stock notification alerts in the dashboard header

Categories and Brands

- Create, edit, or delete categories (e.g., Fresh Bakery)

- **Brand tag dropdown to label product brand (e.g., Amul, Coca-Cola)**

8.3 Finance

- **Total Revenue:** Gross money collected from all customer checkouts.
- **Gross/Net Profit:** Take-home earnings (Revenue minus product costs, rider pay, and taxes).
- **Total Tax Collected:** Total accumulated VAT liabilities for business filings.
- **Total Product Cost:** Total wholesale amount paid out for sold inventory.

8.4 User/Employee Management

Customers

- **Customer list showing name, phone number, and total money spent.**
- **Ban button:** one-tap switch to instantly block fraud users from using the app.

Employee Management

- **Add new employee form (Name, Phone, Role)**
- **Employee roster table listing all active workers**
- **Order counter:** daily tracking of how many orders each employee handled
- **Salary and wage tracker:** monthly salary/daily wage box with payout log
- **Attendance toggle:** quick Present/Absent status switch

8.5 Marketing and CMS

Promo Codes

- **Code text (e.g., FRESH20)**
- **Discount type:** percentage off (e.g., 10% OFF) or flat cash off (e.g., 5 GBP OFF)
- **Minimum order value to activate the coupon**
- **Usage restrictions:** max uses per user, total max uses, expiry date

Banners

- **4 upload boxes for homepage auto-scroll banners**

- **Link target dropdown:** which category opens when customer clicks a banner

8.6 System Settings

- **Store Status:** Master switch to open or close the entire storefront. Auto open/close by time and day.
- **Delivery Areas:** Input boxes to add or remove active delivery postcodes.
- **Free Delivery Threshold:** Checkout amount where delivery fees turn to free (e.g., 15 GBP).
- **Payment Keys:** Input field for Stripe live payment credentials.

9. Order Tracking and Delivery ETA

Order tracking is one of the most critical features for customer satisfaction in a grocery delivery platform. Unlike restaurant delivery where estimated times are auto-calculated by algorithms, a hyperlocal grocery delivery system benefits from rider-driven ETA estimates. The rider knows the local roads, traffic patterns, and parking challenges better than any routing API. This section defines how the rider manually sets the delivery time when dispatching an order, and how that information is communicated to the customer in real-time.

9.1 Tracking Flow Overview

When an order is packed and ready for delivery, the Manager assigns a Rider (or the system auto-assigns based on availability and proximity). The Rider receives a push notification with a sound alert on their phone. They open the order detail screen, review the customer's delivery address and postcode, check the map view for the customer's location, and then manually enter their estimated delivery time (e.g., 45 minutes). This ETA is immediately saved to the database and the customer receives an SMS and in-app notification showing the live countdown timer. The rider can adjust the ETA en route if traffic or other delays occur, and the customer is updated instantly each time.



Figure 6: Order tracking flow — Rider dispatch, manual ETA setting, and live customer tracking

9.2 Phase 1: Rider Dispatch

The dispatch process begins when the Picker marks the order as "Packed" in the Kanban board. The order card moves to the "Out for Delivery" column. The Manager assigns a Rider from the staff list, or the system auto-assigns the nearest available Rider based on their current delivery status. The Rider receives an immediate real-time notification via the WebSocket connection in their phone browser, accompanied by a browser notification (Web Notifications API) and audible alert, ensuring they are alerted even if the browser tab is in the background.

- **WebSocket Notification:** Real-time event via the admin dashboard WebSocket connection, with a browser notification (Web Notifications API) showing "New Delivery" and the order ID. The Rider taps the notification to open the admin dashboard order detail page in their browser. An audible alert plays to catch the Rider's attention even in a noisy environment.
- **Order Detail Screen:** Displays the customer's full delivery address with the postcode prominently highlighted, the customer's name and phone number (tap to call), the list of order items (with Challenge 25 items flagged in red), and a map view showing the customer's pin derived from their postcode via Postcodes.io geocoding.
- **Map Integration:** The map view is embedded in the admin web page using an iframe with Google Maps or Leaflet.js, showing a pin at the customer's postcode centroid. The Rider can tap "Open in Maps" to launch the device's native maps app (Google Maps or Apple Maps) with the customer's address as the destination for turn-by-turn navigation.
- **Customer Contact:** A prominent "Call Customer" button on the order detail page uses a tel: link to initiate a phone call via the device's dialer. This is essential for last-mile issues like finding the correct building or gate code.

9.3 Phase 2: Manual ETA Setting

Once the Rider has reviewed the order details and assessed the delivery location, they manually set the estimated delivery time. This is the core innovation of the tracking system: the Rider, not an algorithm, decides the ETA. The Rider has local knowledge of traffic patterns, road closures, parking availability, and building access that no routing API can fully replicate. The ETA input screen provides quick-tap preset buttons for common times (15, 30, 45, 60 minutes) and a custom number entry field for precise estimates.

- **Quick-Tap Presets:** Four large buttons showing 15, 30, 45, and 60 minutes. Tapping a preset immediately selects it and highlights the button. This allows one-handed operation while on a bicycle or carrying bags.
- **Custom Entry:** A number pad input field where the Rider can type any value from 10 to 90. The minimum is 10 minutes (prevents unrealistic instant delivery promises) and the maximum is 90 minutes (anything longer should trigger a Manager review).

- **"Start Delivery" Button:** Once the ETA is set, the Rider taps "Start Delivery" to confirm. This action: saves the `estimated_delivery_minutes` and calculated `estimated_delivery_at` (current time + ETA) to the orders table, updates the order status to "out_for_delivery", records the `dispatched_at` timestamp, sends an SMS to the customer via Twilio with the ETA and a tracking link, and sends a push notification to the customer's app with the countdown timer.
- **ETA Calculation:** The `estimated_delivery_at` is calculated server-side as: `dispatched_at + estimated_delivery_minutes`. This ensures consistency across time zones and prevents client-side clock manipulation.

9.4 Phase 3: Live Customer Tracking

After the Rider sets the ETA and starts delivery, the customer sees a live tracking experience in their app. The tracking screen is designed to be glanceable: the customer should see the most important information (countdown timer and order status) without scrolling. The screen is divided into three sections: the countdown timer at the top, the status timeline in the middle, and the rider contact card at the bottom.

- **Live Countdown Timer:** A large, prominent display showing "Your order arrives in XX min" that ticks down every second. The timer is calculated client-side from the `estimated_delivery_at` timestamp, with periodic server sync (every 30 seconds) to catch any ETA adjustments. When the timer drops below 5 minutes, the display changes to "Your rider is almost there!" with an animated icon.
- **Status Timeline:** A vertical timeline showing the order's journey: Order Confirmed (with timestamp), Packing Complete (with timestamp), Out for Delivery (with timestamp and ETA), and Delivered (pending). Each completed step has a green checkmark. The current step pulses with a blue indicator. Future steps are grey.
- **Rider Contact Card:** Shows the Rider's first name, vehicle type (bicycle, scooter, car), and phone number. A large "Call Rider" button initiates a phone call. A smaller "Need Help?" link opens the support chat or calls the store number.
- **Push Notifications at Key Moments:** The customer receives push notifications when: the order is packed and assigned a Rider, the Rider starts delivery with the ETA, the ETA is adjusted (with the new time), the rider is arriving (ETA below 5 minutes), and the order is

delivered. Each notification includes the current ETA and a deep link to the tracking screen.

9.5 Phase 4: ETA Adjustments and Edge Cases

Real-world deliveries rarely go exactly to plan. Traffic, parking difficulties, building access issues, and Challenge 25 age verification can all cause delays. The system must handle these gracefully, keeping the customer informed without causing alarm. The Rider can adjust the ETA up to 3 times per delivery, and the customer is notified of each adjustment. If the original ETA passes without delivery, the system automatically alerts the Manager and displays a reassuring message to the customer.

- **" +10 min" Quick Button:** On the Rider's active delivery screen, a prominent "+10 min" button adds 10 minutes to the current ETA. Each tap increments by 10. The adjustment is sent to the server, which recalculates `estimated_delivery_at` and pushes the update to the customer.
- **Maximum 3 Adjustments:** The `eta_adjustment_count` column in the orders table tracks how many times the Rider has updated the ETA. After 3 adjustments, the "+10 min" button is disabled and the Rider must call the store or the customer directly. This prevents excessive adjustments that erode customer trust.
- **ETA Expiry Handling:** If the `estimated_delivery_at` passes without the Rider marking the order as delivered, the system: changes the customer's countdown to "Running slightly late" with a calming message, sends an alert to the Manager in the admin dashboard, and sends the customer an SMS: "Your delivery is taking a little longer than expected. We are on it!"
- **Challenge 25 at Door:** If the order contains age-restricted items and the Rider cannot verify the customer's age, the Rider taps "Cannot Verify" on the delivery screen. The age-restricted items are removed from the delivery, a partial refund is initiated for those items via Stripe, and the customer is notified via SMS and email. The remaining items are delivered normally.
- **Delivery Confirmation:** The Rider taps "Mark Delivered" on their phone. The system records the `delivered_at` timestamp, calculates the actual delivery time (`delivered_at - dispatched_at`) for performance tracking, updates the order status to "delivered", sends a confirmation email and SMS to the customer with a feedback prompt,

and displays a delivery summary on the Rider's screen (delivery time, items delivered, earnings for this delivery).

9.6 Order Tracking API Endpoints

Method	Endpoint	Auth	Description
PATCH	/api/admin/orders/:id/assign-rider	Manager	Assign rider to order, send push notification
PATCH	/api/admin/orders/:id/set-eta	Rider	Rider sets estimated_delivery_minutes, dispatches order
PATCH	/api/admin/orders/:id/adjust-eta	Rider	Rider adjusts ETA en route (max 3 times)
GET	/api/orders/:id/tracking	Cookie	Customer gets tracking data (status, ETA, rider info)
PATCH	/api/admin/orders/:id/verify-age	Rider	Rider confirms age verification at delivery
PATCH	/api/admin/orders/:id/deliver	Rider	Rider marks order as delivered

Table 13: Order tracking API endpoints

9.7 Tracking Database Fields

Column	Type	Purpose
assigned_rider_id	TEXT (FK)	Rider assigned to the delivery
estimated_delivery_minutes	INTEGER	ETA in minutes, set manually by rider
estimated_delivery_at	TEXT	Calculated: dispatched_at + ETA minutes
dispatched_at	TEXT	Timestamp when rider starts delivery
delivered_at	TEXT	Timestamp when rider confirms delivery
eta_adjustment_count	INTEGER	Number of ETA adjustments (max 3)
actual_delivery_minutes	INTEGER	Calculated: delivered_at - dispatched_at

age_verified	BOOLEAN	Whether Challenge 25 check passed
--------------	---------	-----------------------------------

Table 14: Order tracking database fields (added to orders table)

Key Design Decision: The ETA is set manually by the Rider, not calculated by an algorithm. This is intentional. A rider on a bicycle in London knows that crossing the Thames at rush hour takes 20 minutes longer than any map API estimates. Trusting the rider's local knowledge produces more accurate ETAs, which leads to happier customers and fewer "where is my order?" complaints.

10. Mobile Application (Customer Only)

Important Architecture Decision: The mobile app is exclusively for customers. All staff roles (Owner, Manager, Picker, Rider) access the admin dashboard via their phone or desktop browser. There is no separate staff mobile app. This simplifies deployment, eliminates the need for enterprise app distribution, and means all staff operations use the same responsive web application.

The platform provides one native mobile application: the Customer App for browsing, ordering, and tracking deliveries. The app is built using CapacitorJS, which wraps the existing Next.js storefront in a native shell. This approach provides the benefits of native distribution (App Store, Google Play, push notifications, biometric authentication) without the cost and complexity of maintaining a separate React Native or Flutter codebase. The web storefront IS the mobile app; CapacitorJS simply provides the native bridge for device features that browsers cannot access. All staff members, including Riders, use the responsive admin dashboard website on their phone or desktop browser instead of a dedicated app.

Home Screen

- **GPS Postcode Detection:** On first launch, the app requests location permission. If granted, it reverse-geocodes the GPS coordinates to a UK postcode via Postcodes.io. If denied, the customer types their postcode manually. The postcode is validated against the `delivery_zones` table before proceeding.
- **Sticky Header:** Compact header showing the delivery postcode (tap to change), delivery speed estimate ("15 min delivery"), search bar with live predictive results, and cart badge with item count and total.
- **Category Sliders:** Horizontal scroll rows for each product category. Each card shows the product image, name, weight, price, unit price, discount badge (if applicable), and a prominent "ADD" button. Challenge 25 items show an "18+" badge.
- **Banner Carousel:** Auto-scrolling promotional banners at the top, configurable from the admin dashboard. Each banner links to a category or promotion page.

Product Detail Screen

- **Full Product Information:** High-resolution image gallery, product name, brand, weight/volume, price, unit price, VAT-inclusive badge, ingredients list with allergens in bold, use-by date (if applicable), and Challenge 25 warning (if applicable).
- **Add to Cart:** Large, full-width "Add to Cart" button. Quantity selector with +/- buttons. Cart count updates in the header badge immediately with a bounce animation.
- **Cross-Selling:** "Similar Products" and "You Might Also Like" rows below the product detail, populated from products in the same category or with similar tags.

Cart and Checkout

- **Slide-Out Cart Sidebar:** Swipe left from the right edge or tap the cart badge to open. Shows all items with quantity controls, a running bill summary with VAT breakdown, promo code input field, delivery fee, and a large "Proceed to Pay" button.
- **Checkout Flow:** Delivery address confirmation (auto-filled from postcode + address lookup), delivery time display, order summary, cancellation rights notice, and Stripe payment sheet. The entire payment is handled by Stripe's native mobile SDK with 3D Secure support.

- **Guest Checkout:** Customers can check out with just an email address. After payment, they are prompted to set a password to create a full account for order tracking and reorder history.

Order Tracking Screen

The order tracking screen is the most-used screen after the home page. Customers check it repeatedly while waiting for their delivery, so it must be fast, glanceable, and always up-to-date. The screen is divided into three sections: the live countdown timer at the top, the status timeline in the middle, and the rider contact card at the bottom. The ETA displayed to the customer is the same ETA that the Rider manually sets when dispatching the order (see Section 9 for the full tracking flow).

- **Live Countdown Timer:** Large, prominent display: "Your order arrives in XX min". Ticks down every second. Syncs with server every 30 seconds. Changes to "Almost there!" when under 5 minutes. This is the exact time the Rider set when they dispatched the order.
- **Status Timeline:** Vertical timeline: Confirmed, Packing, Out for Delivery, Delivered. Green checkmarks for completed steps, blue pulse for current step, grey for pending. Each completed step shows a timestamp.
- **Rider Info Card:** Rider name, vehicle type, phone number. One-tap "Call Rider" button. "Need Help?" support link. This information appears as soon as the Rider is assigned and starts delivery.
- **Push Notifications:** Automatic notifications at each status change: order confirmed, packing complete, out for delivery (with ETA), ETA adjusted (with new time), rider arriving, and delivered. Deep links open the tracking screen directly.

Order History Screen

- **Past Orders List:** Chronological list of all past orders showing order ID, date, item count, and total amount. Each order card is tappable to view the full details.
- **One-Tap Reorder:** A "Reorder" button on each past order that adds all items back to the cart in one tap. Items that are no longer in stock are highlighted with an "Unavailable" badge and skipped.
- **VAT Receipt:** Each order detail shows a full receipt with item-level pricing, VAT breakdown per item, delivery fee, discount, and total. Customers can screenshot this for expense claims.

Account and Settings

- **Biometric Login:** Face ID (iOS) or fingerprint (Android) for returning users. Falls back to magic link email if biometrics fail. Session lasts 7 days.
- **Saved Addresses:** Manage delivery addresses. Set default address. Postcode validation on save. Each address stores the full address plus the postcode for delivery zone validation.
- **Notification Preferences:** Toggle push notifications for order updates, delivery reminders, and promotional offers. Respects PECR consent requirements (see Section 11.12). Customers can opt out of marketing notifications without losing order update notifications.
- **Delete My Account:** GDPR-compliant account deletion flow (see Section 11.1). Anonymises personal data, retains order records for HMRC, and sends a confirmation email. Must complete within 30 days.
- **Payment Methods:** View saved cards (stored by Stripe, not on our servers). Add or remove cards via Stripe's native payment sheet.

10.2 Staff Access via Responsive Website

All staff roles (Owner, Manager, Picker, Rider) access the admin dashboard through their phone or desktop browser. There is no separate staff mobile app. This architectural decision was made for several important reasons: it eliminates the need for enterprise app distribution (Apple Business Manager, TestFlight, internal testing tracks), it removes the cost and maintenance of a second CapacitorJS build, it allows instant updates via Vercel deployment without waiting for app store review, and it simplifies the overall codebase by having one responsive web application serve all roles. The admin dashboard is designed mobile-first so that all staff screens work perfectly on phone browsers, with particular attention to the Rider experience since Riders use the website on their phone while on the road.

Rider Mobile Web Experience

The Rider uses the admin dashboard on their phone browser (Chrome on Android or Safari on iOS). When the Manager assigns a delivery, the Rider does not receive a push notification to a native app. Instead, the admin website uses a persistent WebSocket connection to deliver real-time updates. When the Rider has the admin dashboard open in their browser, new delivery assignments appear instantly with a browser notification (via the Web Notifications API) and an audible alert sound. The Rider can also enable browser notifications so they receive alerts even when the browser

tab is in the background.

- **Delivery Queue View:** The Rider sees the "Out for Delivery" Kanban column on their phone browser. Assigned orders appear as cards with order ID, customer name, item count, delivery postcode, and status. The interface uses large touch targets (minimum 48x48px) for easy one-handed use while on a bicycle or carrying bags.
- **Order Detail Page:** Tapping a delivery card opens the order detail page showing: customer full name and phone number (tap to call using tel: link), delivery address with postcode highlighted, an embedded map view showing the customer pin from their postcode (using an iframe with Google Maps or Leaflet), the list of order items with Challenge 25 items flagged in red, and a manual ETA input field with quick-tap preset buttons (15, 30, 45, 60 minutes).
- **Manual ETA Setting:** The Rider reviews the customer postcode and map location, then sets the delivery time manually (e.g., 45 minutes) using the quick-tap buttons or a custom number entry. Tapping "Start Delivery" saves the ETA to the database, updates the order status to "out_for_delivery", and triggers an SMS and push notification to the customer showing the same ETA. See Section 9 for the complete tracking flow.
- **Active Delivery Page:** While delivering, the Rider sees a countdown timer matching what the customer sees, a "+10 min ETA" quick button (max 3 adjustments), a "Call Customer" button using the tel: link, Challenge 25 verification buttons ("Verify Age" green, "Cannot Verify" red), and a large "Mark Delivered" confirmation button. All these controls are optimised for mobile browser use with large tap targets and high-contrast colours.
- **Real-Time Connection:** The admin dashboard uses a WebSocket connection (via Socket.io or Vercel Server-Sent Events) to receive instant order updates. If the connection drops, the page automatically reconnects and syncs the latest state. The Rider is shown a "Reconnecting..." indicator when the connection is lost.

Picker Mobile Web Experience

- **Kanban Access:** Pickers see only the "New" and "Packing" columns of the Kanban board on their phone or tablet browser. They can accept new orders and mark them as packed, which moves the order to the "Out for Delivery" column for the Manager to assign a Rider.
- **Stock Updates:** Pickers can update stock counts directly from the product detail page on their phone browser while walking the

warehouse aisles. This is faster and more accurate than returning to a desktop computer.

Manager and Owner Experience

- **Full Dashboard:** Managers and Owners access the complete admin dashboard via desktop or tablet browser. This includes all Kanban columns, product management, staff management, finance reports, and system settings. The responsive design ensures all features work on any screen size.
- **Rider Assignment:** The Manager assigns Riders to orders from the Kanban board. When a Rider is assigned, the Rider's browser receives a real-time WebSocket event with a sound alert, and the delivery card appears in their queue instantly.

10.3 Technical Architecture

Component	Customer App (Native)	Staff Dashboard (Website)
Framework	CapacitorJS 5 wrapping Next.js 14	Next.js 14 responsive web app (same codebase)
Distribution	App Store + Google Play (public)	Secure URL — admin.yourstore.co.uk
Authentication	Magic link + Biometric (Face ID / fingerprint)	Email + password + 2FA TOTP (staff only)
Real-Time Updates	Push notifications (FCM/APNs)	WebSocket / Server-Sent Events in browser
Offline Support	Cart cached. Browse last-viewed. Tracking shows last known status.	Minimal — requires active connection. Delivery actions queued.
Update Mechanism	CapacitorJS Live Update + quarterly store update	Instant — deploy to Vercel, live immediately
App Store Review	Apple (4-7 days) + Google Play (1-3 days)	N/A — website, no review required
Native Permissions	Location, Notifications, Camera (optional)	Browser permissions only (notifications, location)
Payment Exemption	Physical Goods exemption (no 30% commission)	N/A — payments on customer side only

Minimum OS	iOS 15+ / Android 8+	Any modern browser (Chrome 90+, Safari 15+)
------------	----------------------	--

Table 15: Technical architecture — Customer native app vs Staff responsive website

10.4 CapacitorJS Configuration (Customer App Only)

CapacitorJS wraps the existing Next.js storefront in a native mobile shell for the Customer App only. The web app is built once using "next build" and "next export" (static HTML), then CapacitorJS copies the output into the native iOS and Android projects. This means the same storefront codebase serves both the website and the mobile app, with CapacitorJS plugins providing access to native device features that the browser cannot reach. Staff do not use this app; they access the admin dashboard directly in their browser.

Plugin	Purpose	Customer App
@capacitor/geolocation	GPS location for postcode detection	Yes
@capacitor/push-notifications	FCM/APNs push with sound and badge	Yes
@capacitor/haptics	Vibration feedback on order events	Yes (subtle)
@capacitor/biometric-auth	Face ID / fingerprint login	Yes
@capacitor/network	Offline detection and queue management	Yes
@capacitor/live-update	Over-the-air web asset updates	Yes
@capacitor/camera	Photo for profile or future features	Optional

Table 16: CapacitorJS plugin configuration for the Customer App

10.5 App Store Submission Requirements

Since the mobile app is only for customers, only one app needs to go through the App Store and Google Play review process. There is no staff app to distribute, which eliminates the need for Apple Enterprise Certificates (299 GBP/year), TestFlight internal testing, or Google Play Internal Testing tracks for staff devices. This is a significant cost and complexity saving.

Apple App Store

- **Apple Developer Program:** 99 GBP/year. Enrol at developer.apple.com. Required for App Store distribution and push notification certificates.
- **App Store Review:** The app will be reviewed by Apple (typically 4-7 days). Key review considerations: the Physical Goods exemption must be clearly communicated (groceries are physical items delivered outside the app), the app must not mention other payment methods outside the Stripe flow, the privacy policy must be linked in the App Store listing and within the app, and the app must not request unnecessary permissions.
- **App Store Listing:** Screenshots for iPhone (6.7" and 5.5"), iPad (12.9"), app description emphasising fast local delivery, UK compliance (Challenge 25, allergen info), and secure Stripe payments. Age rating: 4+ (no restricted content in the app itself).
- **Privacy Nutrition Labels:** Apple requires a detailed declaration of data collected. Declare: contact info (email, phone), location (postcode), purchases (order history), and identifiers (device ID for push). Do not collect data not listed, or Apple may reject the app.

Google Play Store

- **Google Play Developer:** 25 USD one-time fee. Enrol at play.google.com/console. Required for Google Play distribution and FCM push notifications.
- **Google Play Review:** Typically 1-3 days. Google is less strict than Apple but still reviews for policy compliance. Ensure the Physical Goods exemption is documented and that no in-app billing is used for grocery payments.
- **Data Safety Section:** Google requires a Data Safety declaration. Declare: location (approximate for postcode), personal info (email, phone), and app activity (order history). Declare that data is encrypted in transit and that users can request data deletion.

10.6 Offline Support and Performance

Mobile delivery happens in the real world, where network connectivity is unreliable. The Customer App needs offline support for browsing and cart persistence. The admin dashboard (used by all staff including Riders) requires an active connection for real-time Kanban updates via WebSocket, but critical delivery actions should be queued locally when connectivity drops and synced on reconnect.

- **Customer App Offline:** The cart is stored in `localStorage` and persists across sessions. Previously viewed product categories are cached using a Service Worker with stale-while-revalidate strategy. The order tracking screen shows the last known status and ETA, with a "Reconnecting..." indicator. The user can browse cached products but cannot place orders without connectivity.
- **Staff Dashboard Offline:** The admin dashboard requires an active WebSocket connection for real-time order updates. If the connection drops, the Rider sees a "Reconnecting..." banner and can still view the current delivery details (cached in memory). The "Mark Delivered" action is queued in `localStorage` and synced when the connection is restored. The queue is processed in order, with idempotency keys to prevent duplicate updates. Phone calls to the customer (via tel: links) work without internet.
- **Performance Targets:** Time to Interactive under 3 seconds on 4G. First Contentful Paint under 1.5 seconds. Lighthouse Performance score above 90. Cart operations (add/remove) respond in under 100ms (optimistic UI updates). Tracking countdown updates every second without jank. Admin dashboard Kanban loads in under 2 seconds. WebSocket reconnection within 5 seconds of connection drop.

11. UK Laws, Regulations, and Compliance

Operating a grocery delivery service in the United Kingdom requires strict compliance with a complex web of overlapping regulatory frameworks. Failure to comply can result in significant fines, criminal prosecution, and reputational damage. This section identifies every major UK law and regulation that applies to your platform, explains what each law requires, and provides a detailed implementation plan showing exactly how your system will achieve compliance. Each subsection follows a consistent structure: the legal requirement is stated first, followed by the specific technical and operational measures your platform will implement to meet that requirement.

11.1 UK GDPR and Data Protection Act 2018

The UK General Data Protection Regulation (UK GDPR), retained after Brexit via the Data Protection Act 2018 (DPA 2018), is the primary legislation governing how personal data is collected, stored, processed, and deleted. For a grocery delivery platform, personal data includes customer names, delivery addresses, phone numbers, email addresses,

order history, and payment information. Non-compliance can result in fines of up to 17.5 million GBP or 4% of annual global turnover, whichever is higher. The Information Commissioner's Office (ICO) is the UK supervisory authority responsible for enforcement.

Legal Requirements

- **Lawful basis for processing:** You must identify and document a lawful basis for every personal data processing activity. For order fulfilment, "contractual necessity" (Article 6(1)(b)) applies. For marketing emails, "legitimate interest" (Article 6(1)(f)) applies with a documented Legitimate Interest Assessment. For cookies and analytics, "consent" (Article 6(1)(a)) is required.
- **Data minimisation:** Only collect personal data that is strictly necessary for the stated purpose. Do not ask for a customer's date of birth unless they are purchasing age-restricted items. Do not collect national insurance numbers, passport numbers, or other unnecessary identifiers.
- **Purpose limitation:** Data collected for order delivery cannot be repurposed for unrelated marketing without separate consent. Each purpose must be documented in your Records of Processing Activities (ROPA).
- **Storage limitation:** Personal data must not be kept longer than necessary. Order data required for HMRC must be retained for 7 years. Customer PII should be deleted 30 days after account closure, with order records anonymised.
- **Data subject rights:** Customers have the right to access their data (Subject Access Requests), rectify inaccuracies, erase data (right to be forgotten), restrict processing, data portability, and object to processing. SARs must be fulfilled within 30 calendar days without charge.
- **Breach notification:** Personal data breaches must be reported to the ICO within 72 hours of becoming aware of the breach. If the breach is likely to result in a high risk to individuals, you must also notify affected customers without undue delay.
- **Data Protection Impact Assessment (DPIA):** A DPIA is required before processing that is likely to result in a high risk to individuals, such as large-scale processing of location data or systematic monitoring.
- **ICO registration:** Every organisation that processes personal data must register with the ICO as a data controller and pay the annual data protection fee (approximately 40 GBP for small businesses, or 60

GBP for medium).

How We Will Comply

- **ICO Registration:** Register with the ICO at ico.org.uk before processing any personal data. Select "Retail" as the primary business activity and "Online Sales" as a secondary activity. The annual fee is approximately 40 GBP. Add a renewal reminder in your calendar.
- **Privacy Notice:** Create a comprehensive privacy policy page accessible from the footer of every page. It must include: the identity and contact details of the data controller, the purposes of processing, the lawful basis for each purpose, data retention periods, third-party recipients (Stripe, Resend, Twilio, Turso), international transfer details (US servers for Vercel/Stripe with Standard Contractual Clauses), and how to exercise data subject rights. Use plain English, not legal jargon.
- **Cookie Consent Banner:** Implement a GDPR-compliant cookie consent banner using a library like Cookiebot or Osano. The banner must: appear before any non-essential cookies are set, provide granular controls (essential, analytics, marketing), allow users to accept or reject specific categories, record consent with a timestamp, and provide an easy way to withdraw consent later via a floating settings icon. Block Google Analytics and Facebook Pixel scripts until the user explicitly opts in.
- **Subject Access Request (SAR) Handler:** Build an admin panel feature at `/admin/data-requests` that: verifies the identity of the requester, compiles all data associated with the user (profile, orders, delivery addresses, notifications), exports as a machine-readable JSON file within 30 days, and logs the request and response in the `audit_log` table. Charge no fee for the first copy.
- **Data Erasure Workflow:** Implement a "Delete My Account" feature in customer settings that: anonymises the user record (replace name with "Deleted User", remove email and phone), retains order records with anonymised `user_id` for HMRC compliance, deletes the Vercel KV session, and sends a confirmation email to the original address stating deletion is complete. This process must complete within 30 days of the request.
- **Data Encryption:** All PII (names, addresses, phone numbers) encrypted at rest using AES-256 via Turso's built-in encryption. All data in transit over TLS 1.3 (enforced by Vercel). Database backups encrypted with a separate key stored in Vercel environment variables.

- **Records of Processing Activities (ROPA):** Maintain a living document (spreadsheet or Notion page) listing every data processing activity: what data you collect, why, the lawful basis, who you share it with, how long you keep it, and where it is stored. This must be available for ICO inspection on request.
- **Breach Response Plan:** Create a documented incident response procedure (see Section 14.3) that includes: immediate containment steps, assessment of breach severity, ICO notification within 72 hours using the ICO online form, customer notification if high risk, root cause analysis, and remediation steps. Assign the Owner role as the Data Protection Officer (DPO) responsible for breach reporting.
- **Third-Party Data Processing Agreements:** Sign Data Processing Agreements (DPAs) with Stripe, Vercel (Turso), Resend, and Twilio. These are typically available in the settings of each service. Store signed DPAs in a compliance folder. Ensure all processors are UK GDPR-compliant and that US-based processors rely on UK Extension to Standard Contractual Clauses.
- **Staff Training:** All staff must complete UK GDPR awareness training before accessing customer data. This includes understanding what constitutes personal data, how to handle SARs, the importance of data minimisation, and the breach reporting procedure. Document completion in the staff_attendance table.

11.2 Consumer Rights Act 2015

The Consumer Rights Act 2015 (CRA 2015) establishes the statutory rights that consumers have when buying goods and services. For a grocery delivery platform, this means every product must meet the statutory quality thresholds, and every service (delivery) must be performed with reasonable care and skill. The Act also provides consumers with a 30-day right to reject faulty goods and claim a full refund. Importantly, the burden of proof is on the trader for the first 30 days (the goods are assumed faulty unless the trader can prove otherwise), and on the consumer after 30 days.

Legal Requirements

- **Satisfactory quality:** Goods must be of a standard that a reasonable person would consider satisfactory, taking into account the price, description, and any other relevant factors. For groceries, this means fresh produce must not be bruised or wilted, cold items must arrive at the correct temperature, and products must not be past their use-by

date.

- **Fit for purpose:** Goods must be fit for the purpose for which they are commonly supplied, or for any specific purpose the customer made known to the trader before purchase. If a customer asks "is this gluten-free?" the answer must be accurate.
- **As described:** Goods must match their description on the website, including weight, volume, brand, and any other attributes. A 500g pack of rice cannot be 450g. A "British beef" product cannot be imported from another country.
- **Right to reject (30 days):** If goods are faulty, the consumer has the right to reject them within 30 days and receive a full refund. This includes incorrect items, damaged goods, and items that do not match their description.
- **Right to repair or replacement:** After 30 days but within 6 months, the consumer can request a repair or replacement. If this is not possible or takes an unreasonable time, a price reduction or final right to reject applies.

How We Will Comply

- **Accurate Product Descriptions:** The products table includes name, description, weight_value, weight_unit, brand_id, and ingredients fields. Every product entry must be reviewed by the Manager before publishing (is_active = TRUE). The admin product form must validate that weight and volume are numeric and that the description is at least 20 characters. Use the Zod schema on the product creation API endpoint to enforce this validation at the server level.
- **Quality Assurance at Packing:** The Picker role in the Kanban board must visually inspect each item before marking it as packed. The packing screen will display the product name, expected condition (e.g., "Check use-by date", "Check for damage"), and a checkbox for the Picker to confirm the item meets quality standards. If an item fails QA, the Picker flags it, the customer is notified, and a substitution or refund is offered.
- **Refund Workflow:** The admin panel includes a dedicated "Refunds" section accessible to Manager and Owner roles. When a customer reports a faulty item, the staff member can: select the specific order, choose the affected items, select a reason (Damaged, Incorrect, Quality Issue, Wrong Item), and initiate a full or partial refund via the Stripe API. The refund is processed instantly, the order record is updated with the refund amount and reason, and the customer

receives an email confirmation.

- **30-Day Guarantee Statement:** Display a clear guarantee on the checkout page and in order confirmation emails: "If any item is damaged, incorrect, or not as described, you are entitled to a full refund within 30 days of delivery. Contact our support team to initiate a return." This statement ensures customers are aware of their rights before purchase.
- **Service Quality (Delivery):** Track delivery performance metrics in the admin dashboard: on-time delivery rate, average delivery time, and customer complaints per delivery. If the delivery time exceeds the promised window by more than 15 minutes, the system automatically flags the order for a delivery fee refund. This ensures the delivery service meets the "reasonable care and skill" standard.

11.3 Consumer Contracts (Information, Cancellation and Additional Charges) Regulations 2013

These regulations (often called the "Distance Selling Regulations") apply specifically to contracts made at a distance (online, by phone, or by email). They require traders to provide specific pre-contract information, grant consumers a 14-day cancellation right for most goods, and prohibit certain unfair practices like hidden charges and pre-ticked payment boxes. For a grocery delivery platform, the cancellation rights have important exceptions for perishable goods.

Legal Requirements

- **Pre-contract information:** Before a customer places an order, you must provide: the trader's identity and contact details, a description of the goods, the total price including all taxes and charges, delivery costs and arrangements, the cancellation rights period, and the complaint handling policy.
- **14-day cancellation right:** Consumers have 14 calendar days from the day after receiving goods to cancel the contract, without giving a reason. The trader must refund within 14 days of receiving the cancellation notice.
- **Perishable goods exception:** The 14-day cancellation right does NOT apply to goods that deteriorate rapidly (fresh produce, dairy, meat, fish, bakery items). Once delivered, the customer cannot cancel for a refund simply because they changed their mind.
- **Sealed goods exception:** The 14-day right does NOT apply to sealed goods that have been unsealed after delivery and are not suitable for

return due to health protection or hygiene reasons (e.g., a sealed bag of salad that has been opened).

- **Non-perishable goods:** The 14-day right applies in full to non-perishable items (household goods, canned goods, toiletries). The customer can return these within 14 days for any reason.
- **No hidden charges:** All charges must be transparent before the customer commits to purchase. No pre-ticked boxes for add-ons. Delivery fees must be shown before the checkout page.
- **Order confirmation:** The customer must receive written confirmation of the contract (order confirmation email) on a durable medium within a reasonable time, and no later than the delivery of the goods.

How We Will Comply

- **Pre-Contract Information Display:** The checkout page must display, above the "Proceed to Pay" button: the company name and registered address, a summary of the order with individual prices, the delivery fee and any applicable discounts, the total price including VAT, the estimated delivery time, a link to the cancellation policy, and a link to the complaints procedure. Use a structured "Order Summary" component that is visible before the customer enters payment details.
- **Cancellation Policy Page:** Create a dedicated /cancellation-rights page that clearly explains: the 14-day cancellation right for non-perishable goods, the perishable goods exception with a list of what qualifies as perishable, how to cancel (email link, phone number, or in-app cancellation button), the refund timeline (14 days from receipt of cancellation), and who pays for return delivery (the customer, unless the goods are faulty). This page must be linked from the checkout page and the order confirmation email.
- **Perishable vs Non-Perishable Classification:** Add a column "is_perishable" (BOOLEAN) to the products table. Set is_perishable = TRUE for fresh produce, dairy, meat, fish, and bakery items. The checkout system will read this flag to determine which items in the order are subject to the 14-day cancellation right and which are exempt. Display a clear message at checkout: "Fresh items (marked with a leaf icon) are exempt from the 14-day cancellation right as they are perishable. All other items may be returned within 14 days."
- **In-App Cancellation Button:** For orders not yet dispatched, display a "Cancel Order" button on the order detail page. Clicking it triggers an API call that: sets the order status to "cancelled", records the cancellation_reason, initiates a Stripe refund (full if before packing,

partial if after packing), restores inventory, and sends a cancellation confirmation email. The button is hidden once the order status reaches "Out for Delivery".

- **Transparent Pricing:** Display delivery fees on the cart sidebar before the customer reaches checkout. Show a running total that includes item total, delivery fee, discount, and VAT breakdown. Never add charges after the customer has entered their payment details. The checkout total shown must be the final amount charged.
- **Order Confirmation Email:** Automatically send an order confirmation email via Resend within 60 seconds of payment. The email must include: order number, itemised list with prices, delivery address, estimated delivery time, cancellation rights summary, and a link to the full cancellation policy. Store the email send status in the notifications table for audit purposes.

11.4 Food Information Regulations 2014 (FIC) and Natasha's Law

The Food Information Regulations 2014 (FIR 2014) implement the EU Food Information to Consumers Regulation (FIC) in UK law. They mandate that specific information must be provided to consumers before they purchase food, including the full ingredients list, allergen information, net quantity, and use-by dates. Natasha's Law (UKPP - UK Prepacked for Direct Sale), which came into force on 1 October 2021, adds further requirements for food that is prepacked for direct sale: it must have a full ingredients list with allergens emphasised on the label. For an online grocery platform, this means every product page must display all mandatory food information before the customer adds the item to their cart.

Legal Requirements

- **Mandatory food information:** The following must be provided for every food product: the name of the food, the full ingredients list (in descending order of weight), the 14 major allergens emphasised (bold, underlined, or highlighted), the net quantity (weight or volume), the use-by or best-before date, any special storage conditions, the name and address of the food business operator, and instructions for use where necessary.
- **Allergen emphasis:** The 14 major allergens (celery, cereals containing gluten, crustaceans, eggs, fish, lupin, milk, molluscs, mustard, nuts, peanuts, sesame, soya, sulphur dioxide) must be emphasised in the

ingredients list, typically using bold text. This is a legal requirement, not optional.

- **Pre-purchase availability:** All mandatory food information must be available to the consumer before they make the purchase. For online sales, this means the product detail page must display the full ingredients list and allergen information, not just the product name and price.
- **Natasha's Law (PPDS):** If your store prepares and packages food on-site for direct sale (e.g., ready-to-eat meal pots, freshly cut fruit packs), these products must have a label with: the name of the food, a full ingredients list with allergens emphasised, and the net quantity. For an online store, this information must be on the product detail page.

How We Will Comply

- **Database Schema for Food Information:** The products table already includes the necessary fields: name, description, ingredients, allergens, weight_value, weight_unit, and use_by_date. Ensure every product record has these fields populated before is_active is set to TRUE. The admin product form must validate that ingredients and allergens are not empty for food products (category_id referencing a food category).
- **Allergen Display:** On the product detail page, render the ingredients list with allergens emphasised in bold. The allergens field in the database stores a comma-separated list (e.g., "Milk, Soya, Wheat"). When rendering, parse this list and wrap each matching ingredient in the ingredients list with a bold tag. Display the allergens list separately above the ingredients for quick scanning, with each allergen in a coloured badge for maximum visibility.
- **Product Card Allergen Icons:** On product listing cards (homepage sliders, category pages), display small icons for the top 3 most common allergens (milk, nuts, gluten) if present. This allows customers with allergies to quickly scan products without opening every detail page.
- **Allergen Filter:** Implement an allergen filter in the category listing page sidebar. Customers can select allergens they need to avoid (e.g., "Contains: Milk, Nuts"), and the product grid filters to show only products that do NOT contain those allergens. This filter reads from the allergens column in the products table.

- **Use-By Date Display:** For products with a `use_by_date` value, display "Use by: DD/MM/YYYY" prominently on the product detail page. Products past their use-by date must automatically be set to `is_active = FALSE` via a daily cron job (Vercel Cron Jobs). It is illegal to sell food past its use-by date in the UK.
- **Pre-Purchase Information Confirmation:** Before the customer can add an item to the cart, the product detail page must be loaded, ensuring the customer has had the opportunity to see the allergen and ingredient information. Do not allow "quick add" from a popup that does not show allergens. The category listing card can have an "ADD" button, but it must display a brief allergen warning ("Contains: Milk, Nuts") if allergens are present.
- **Natasha's Law Compliance for In-Store Prepared Items:** If the store prepares any PPDS items, add a `preparation_type` column to the products table with values: "prepacked" (manufacturer-packaged), "ppds" (prepacked for direct sale), "loose" (sold loose). For PPDS items, the admin form must require a full ingredients list with allergens, and the product detail page must display a "Prepared on premises" badge with the full label information.

11.5 Challenge 25, Licensing Act 2003, and Age Verification

The Licensing Act 2003 governs the sale of alcohol in England and Wales, and equivalent legislation exists in Scotland and Northern Ireland. If your grocery delivery service sells alcohol, you must hold a premises licence and a personal licence. Challenge 25 is a retail strategy that encourages staff to request identification from anyone who looks under 25, providing a safety margin for the legal purchase age of 18. For online sales, the age verification challenge is even more critical because the customer is not physically present at the point of sale. The Licensing Act 2003 (Mandatory Licensing Conditions) Order 2014 requires that age verification is in place for online alcohol sales.

Legal Requirements

- **Premises licence:** If selling alcohol, you must hold a premises licence from your local council. The licence specifies the hours during which alcohol can be sold and must be displayed at the premises.
- **Personal licence:** At least one person involved in the sale of alcohol must hold a personal licence, obtained by passing the Award for Personal Licence Holders (APLH) qualification.

- **Age verification policy:** You must have a documented age verification policy. For online sales, this must include measures to verify the customer's age before completing the sale. The Challenge 25 approach is recommended by the Portman Group and accepted by licensing authorities.
- **Delivery age verification:** The delivery driver must verify the age of the recipient at the point of delivery. If the recipient appears under 25 and cannot produce valid photo ID (passport, driving licence, PASS-accredited proof of age card), the alcohol must not be handed over.
- **Energy drinks:** While not legally restricted, many UK supermarkets voluntarily restrict high-caffeine energy drinks to over-16s. Implementing this restriction demonstrates responsible retailing.
- **Tobacco and tobacco products:** Sale of tobacco products requires a separate registration with HMRC and is subject to strict packaging and display regulations. If selling tobacco, you must also comply with the Tobacco and Related Products Regulations 2016.

How We Will Comply

- **Challenge 25 Database Flag:** The products table already includes the challenge_25 boolean column. Set this to TRUE for all alcohol products (beer, wine, spirits, cider, alcopops), energy drinks with caffeine content above 150mg/L, and any tobacco products. The admin product form includes a toggle switch for this flag.
- **Age Verification at Checkout:** When a customer adds a challenge_25 item to their cart, display a prominent warning on the cart sidebar: "This order contains age-restricted items. Valid photo ID will be required at delivery." At checkout, add a mandatory checkbox: "I confirm that I am 18 or over and that I will provide valid photo ID upon delivery." The order cannot be placed without this confirmation. Store the confirmation timestamp in the order record.
- **Challenge 25 Badge on Product Cards:** Display a prominent "18+" badge or "Challenge 25" icon on product cards and detail pages for all age-restricted items. This ensures customers are aware before adding the item to their cart.
- **Delivery Driver Verification Screen:** The Rider's mobile view of the order detail page includes a prominent section for age-restricted items. It lists each restricted item, displays a "Verify Age" button, and requires the Rider to confirm that they have checked valid photo ID. If the Rider taps "Cannot Verify", the restricted items are removed from

the delivery, a partial refund is initiated for those items, and the incident is logged in the `audit_log` table.

- **Licence Documentation:** Before selling alcohol, obtain a premises licence from the local council where your store is located. Designate at least one staff member (typically the Owner or Manager) to obtain a personal licence by completing the APLH qualification. Store digital copies of both licences in the admin settings. Display the premises licence summary on a `/licencing` page accessible from the footer.
- **Energy Drink Age Gate:** Implement a softer age verification for energy drinks. When a customer adds an energy drink (`challenge_25 = TRUE`, `category = "Soft Drinks"`) to the cart, display: "This product contains high caffeine. We recommend it for over-16s only." Unlike alcohol, this is a warning rather than a legal requirement, but implementing it shows responsible retailing and reduces complaint risk.
- **Training Record:** All staff who handle deliveries containing age-restricted items must complete Challenge 25 training. Record training completion in the `staff_attendance` table with `type = "challenge_25_training"`. This documentation protects you in the event of a licensing review.

11.6 Equality Act 2010 and Accessibility

The Equality Act 2010 protects people from discrimination on the basis of protected characteristics, including disability. Under the Act, service providers (including online retailers) must make "reasonable adjustments" to ensure that disabled people can access their services. The Web Content Accessibility Guidelines (WCAG) 2.1 at the AA level are the de facto standard for digital accessibility compliance in the UK. The European Accessibility Act (EAA) will also apply to the UK via the Product Safety and Metrology etc. (Amendment etc.) (EU Exit) Regulations 2019, requiring digital accessibility for e-commerce by June 2025.

Legal Requirements

- **Reasonable adjustments:** You must take positive steps to ensure that disabled people can access your service. For a website, this means the site must be navigable by keyboard, screen-reader compatible, and usable by people with visual impairments, motor disabilities, and cognitive disabilities.
- **WCAG 2.1 AA compliance:** All user-facing components must meet the WCAG 2.1 AA success criteria. This includes: perceivable (text alternatives, captions, adaptable content, distinguishable content),

operable (keyboard accessible, enough time, seizure-safe, navigable), understandable (readable, predictable, input assistance), and robust (compatible with assistive technologies).

- **Accessibility statement:** You must publish an accessibility statement on your website, declaring your compliance level, known issues, and how to request accessible alternatives or report problems.

How We Will Comply

- **WCAG 2.1 AA Implementation:** See Section 5.3 for the detailed accessibility requirements table covering product images, buttons, colour contrast, form labels, keyboard navigation, screen reader support, text resize, and error messages. Every component is tested with axe-core during CI/CD and manually with NVDA screen reader.
- **Keyboard Navigation:** All interactive elements (buttons, links, form inputs, cart operations) must be fully operable using the Tab, Enter, Space, and Escape keys. Add a "Skip to main content" link at the top of every page. Ensure visible focus indicators (minimum 2px solid outline) on all focusable elements.
- **Screen Reader Support:** Use semantic HTML (nav, main, section, article, aside, footer). Add aria-live regions for dynamic content updates (cart item count, order status changes). Use aria-label for icon-only buttons. Ensure form inputs have associated label elements, not just placeholder text.
- **Colour Contrast:** Test all text/background colour combinations with a contrast checker tool (e.g., WebAIM Contrast Checker). Normal text must achieve 4.5:1 contrast ratio. Large text (18px+ bold or 24px+) must achieve 3:1. Never use colour alone to convey information (e.g., add icons alongside colour for "out of stock" badges).
- **Accessibility Statement Page:** Create a dedicated /accessibility page that: states the WCAG compliance level, lists any known accessibility issues with workarounds, provides a contact method for reporting accessibility problems (email and phone), describes the accessibility testing methodology, and commits to a remediation timeline for any identified issues.
- **Ongoing Testing:** Include axe-core automated accessibility testing in the CI/CD pipeline (GitHub Actions). Run manual screen reader testing (NVDA on Windows, VoiceOver on macOS/iOS) before every major release. Conduct an annual third-party accessibility audit.

11.7 VAT Act 1994 and HMRC Compliance

The Value Added Tax Act 1994 governs the collection of VAT in the UK. If your business has a taxable turnover exceeding the VAT registration threshold (currently 90,000 GBP per year as of 2024/25), you must register for VAT with HMRC. Even below this threshold, voluntary registration is recommended for a grocery business because it allows you to reclaim VAT on business purchases. VAT on groceries is particularly complex because different food items attract different rates: most food is zero-rated (0%), but alcohol, soft drinks, confectionery, and some snack foods are standard-rated (20%). Getting VAT wrong can result in HMRC penalties, back-tax assessments, and interest charges.

Legal Requirements

- **VAT registration:** Register for VAT with HMRC within 30 days of your taxable turnover exceeding 90,000 GBP. Voluntary registration is possible below this threshold. Once registered, you must submit quarterly VAT returns via Making Tax Digital (MTD)-compatible software.
- **Correct VAT rates:** Apply the correct VAT rate to every product. Most food is zero-rated, but the following attract the standard 20% rate: alcohol, soft drinks, confectionery, crisps and savoury snacks, ice cream, sports drinks, mineral water, and takeaway hot food. The reduced rate of 5% applies to very few grocery items.
- **VAT-inclusive pricing:** All prices displayed to consumers must be VAT-inclusive. The VAT breakdown must be shown on receipts. B2B prices may be shown exclusive of VAT, but this platform is B2C, so all prices include VAT.
- **VAT receipts:** Every receipt must show: the VAT registration number, the total VAT amount, and a breakdown of VAT by rate (0%, 5%, 20%). This is a HMRC requirement for VAT-registered businesses.
- **Making Tax Digital (MTD):** VAT-registered businesses must keep digital records and submit VAT returns using MTD-compatible software. Your platform must be capable of exporting VAT data in a format compatible with HMRC-recognised MTD software.

How We Will Comply

- **VAT Rate Configuration:** The products table includes a `vat_rate` column storing 0.00, 0.05, or 0.20 for each product. The admin product form includes a VAT selector dropdown with these three options. When a Manager creates a product, the system suggests a default VAT rate based on the selected category (e.g., category

"Alcohol" defaults to 20%, category "Fresh Vegetables" defaults to 0%). The Manager can override the suggestion but is warned if the override seems incorrect.

- **Server-Side VAT Calculation:** All VAT calculations happen on the server. The `/api/orders` endpoint recalculates the total by looking up each product's price and `vat_rate` from the database, not from client-submitted values. The order record stores `subtotal` (pre-VAT), `vat_total` (total VAT), and `total` (final amount). The `order_items` table snapshots the `vat_rate` for each item at the time of purchase, ensuring accurate historical records even if rates change.
- **VAT Breakdown on Receipt:** The order confirmation email and the in-app order detail page display a VAT summary section showing: total zero-rated items and their value, total standard-rated items and their value, the VAT amount for each rate, and the total VAT. The format follows HMRC guidance for VAT invoices.
- **Finance Dashboard:** The admin finance section includes a "VAT Collected" report that shows: total VAT collected per month, broken down by rate (0%, 5%, 20%), with an export button that generates a CSV file compatible with Xero, QuickBooks, or FreeAgent for MTD submission. This report reads from the `orders` and `order_items` tables, summing `vat_total` by month.
- **HMRC Registration:** Register for VAT at gov.uk/register-for-vat. If your expected turnover is below the threshold, consider voluntary registration to reclaim VAT on stock purchases, delivery vehicle costs, and technology expenses. Set a quarterly reminder in the admin calendar for VAT return submission deadlines.

11.8 Electronic Commerce Regulations 2002

The Electronic Commerce (EC Directive) Regulations 2002 apply to any business providing an information society service (i.e., a service provided over the internet). They require specific information to be provided to consumers, establish rules for commercial communications, and set out requirements for the conclusion of electronic contracts. These regulations work alongside the Consumer Contracts Regulations and GDPR.

Legal Requirements

- **Service provider information:** Your website must display: the name of the service provider, the geographic address, the email address, the company registration number (if a limited company), and the VAT registration number (if VAT-registered).

- **Commercial communications:** Any promotional content (banners, discount codes, product offers) must be clearly identifiable as a commercial communication and must identify the person on whose behalf it is sent.
- **Contract formation:** The technical steps to conclude a contract must be clear. The customer must be able to identify and correct input errors before placing the order. Acknowledgement of receipt must be sent without undue delay.
- **Terms and conditions:** The terms and conditions governing the contract must be available to the customer, stored, and accessible. The customer must be able to store and reproduce them.

How We Will Comply

- **Footer Company Information:** The website footer must display: the company trading name, the registered office address (or principal place of business if a sole trader), the company email address, the Companies House registration number (if applicable), and the VAT registration number (once registered). This information must be visible on every page.
- **Terms and Conditions Page:** Create a comprehensive /terms-and-conditions page covering: the contract formation process (order placed, payment taken, order confirmed), pricing and payment terms, delivery terms and timescales, cancellation and returns policy, liability limitations, dispute resolution, and governing law (English law). Link this page from the footer and from the checkout page. The customer must tick a checkbox confirming they have read and agree to the T&Cs; before placing an order. Store the acceptance timestamp in the order record.
- **Order Review Step:** Before the final "Place Order" button, display a full order review screen showing all items, quantities, prices, delivery address, and total. Include a prominent "Edit" button next to each section so the customer can correct any errors. This satisfies the requirement for the customer to identify and correct input errors before the contract is formed.
- **Order Acknowledgement:** Send an order confirmation email within 60 seconds of payment. This email serves as the acknowledgement of receipt required by the Regulations. Include the order number, itemised list, total, delivery address, and estimated delivery time.
- **Commercial Communications Labelling:** All promotional banners on the homepage must be clearly commercial in nature (they already are,

as they display product discounts and offers). If using affiliate links or sponsored product placements, clearly label them as "Sponsored" or "Ad".

11.9 Payment Services Regulations 2017 and Strong Customer Authentication

The Payment Services Regulations 2017 (PSR 2017) implement the EU's second Payment Services Directive (PSD2) in UK law. The most significant requirement for e-commerce is Strong Customer Authentication (SCA), which mandates that online payments must use two-factor authentication. Since the UK left the EU, the FCA has adopted the SCA requirements into UK law with some modifications. In practice, Stripe handles SCA compliance automatically via 3D Secure (3DS), but your platform must ensure that 3DS is enabled and not bypassed.

Legal Requirements

- **Strong Customer Authentication (SCA):** Online payments must use at least two of three authentication factors: something the customer knows (PIN/password), something the customer has (phone/hardware token), and something the customer is (biometric). In practice, this is implemented via 3D Secure 2 (3DS2).
- **Exemptions:** SCA exemptions exist for low-value transactions (under 30 GBP), recurring payments, and trusted beneficiaries. Stripe can automatically request these exemptions.
- **Refund rights:** The payer has the right to a refund for unauthorised transactions. You must have a process for handling refund requests and chargebacks.

How We Will Comply

- **Stripe 3D Secure Configuration:** Configure Stripe to always request 3D Secure authentication when required by the card issuer. In the Stripe dashboard, set "3D Secure" to "Automatic" mode, which triggers 3DS only when the card issuer requires it. In the PaymentIntent creation API call, set `request_three_d_secure = "automatic"`. This ensures SCA compliance without unnecessarily friction for low-risk transactions.
- **Payment Intent Flow:** When the customer clicks "Pay", the server creates a Stripe PaymentIntent with the calculated total (server-side). The client receives the `client_secret` and uses Stripe.js to confirm the payment. If 3DS is required, Stripe.js automatically shows the 3DS

challenge modal. The result is sent to the server via webhook (payment_intent.succeeded or payment_intent.requires_payment_method).

- **Chargeback Handling:** Monitor chargebacks via the Stripe dashboard. Build a webhook handler for charge.dispute.created events that alerts the Owner via in-app notification and email. Document the dispute reason and gather evidence (delivery confirmation, order details, customer communications) within the 7-day response window. Maintain a chargeback rate below 0.75% to avoid Stripe account review.
- **Refund Process:** The admin panel includes a refund initiation feature (Manager+ role) that calls the Stripe Refunds API. Partial refunds are supported for individual items. Full refunds reverse the entire payment. All refunds are logged in the audit_log table with the reason and the staff member who initiated them.

11.10 Food Safety Act 1990 and Food Hygiene Regulations 2006

The Food Safety Act 1990 is the primary legislation governing food safety in the UK. It makes it an offence to sell food that is not of the nature, substance, or quality demanded, or to sell food that is unfit for human consumption. The Food Hygiene (England) Regulations 2006 (and equivalent regulations in Scotland, Wales, and Northern Ireland) require food businesses to implement food safety management procedures based on HACCP (Hazard Analysis and Critical Control Points) principles. For a grocery delivery service, this includes temperature control during storage and transport, particularly for chilled and frozen items.

Legal Requirements

- **Food safety management:** Implement a food safety management system based on HACCP principles. Identify critical control points (receipt of goods, storage, picking, delivery) and implement monitoring procedures.
- **Temperature control:** Chilled food must be kept below 8 degrees Celsius during storage and transport. Frozen food must be kept at or below -18 degrees Celsius. Hot food must be kept above 63 degrees Celsius.
- **Food hygiene rating:** Your business will be inspected by the local authority and given a Food Hygiene Rating (0-5). This rating must be displayed prominently. Online food businesses are encouraged to

display their rating on their website.

- **Traceability:** You must be able to trace food one step back (who supplied it) and one step forward (who you sold it to). This is critical for product recalls.
- **Product recall procedure:** You must have a documented procedure for withdrawing or recalling unsafe food from the market and notifying customers and the Food Standards Agency (FSA).

How We Will Comply

- **HACCP Plan:** Create a documented HACCP plan covering: delivery of stock to the store (temperature check on arrival), storage (refrigeration monitoring), picking (checking use-by dates, visual quality inspection), packing (separating raw and cooked items, cold chain maintenance), and delivery (insulated bags, delivery time limits). Store the HACCP plan document in the admin settings for staff access.
- **Temperature Monitoring at Delivery:** For orders containing chilled or frozen items, the Rider's delivery screen displays a "Temperature Check" prompt upon delivery. The Rider records the temperature reading from an insulated bag thermometer. If the reading exceeds 8 degrees Celsius for chilled items or -18 degrees Celsius for frozen items, the Rider flags the order and the customer is offered a refund for temperature-sensitive items. Record temperature readings in a `delivery_temperature_log` table.
- **Use-By Date Enforcement:** Implement a daily Vercel Cron Job that queries the `products` table for items where `use_by_date` is earlier than today's date and sets `is_active = FALSE`. This prevents the sale of out-of-date food, which is a criminal offence under the Food Safety Act. Send a notification to the Manager listing the items that have been automatically deactivated.
- **Food Hygiene Rating Display:** Once inspected, display the Food Hygiene Rating badge in the website footer and on the About page. Include a link to the FSA ratings website (ratings.food.gov.uk) for verification. This builds customer trust and demonstrates compliance.
- **Traceability Records:** The `wastage_log` table tracks expired, damaged, and recalled items. The `order_items` table provides forward traceability (what was sold to whom). For backward traceability, add a `supplier_batch` column to the `products` table for batch-level tracking. If a recall is issued, query the `order_items` table for affected product batches and email all affected customers.

- **Product Recall Feature:** Build an admin feature at `/admin/recalls` that: allows the Owner to select a product and reason for recall, queries all orders containing that product within the last 7 days, sends an email to all affected customers via Resend with recall instructions, marks the product as inactive, and logs the recall in the `audit_log` table. The recall email must include: the product name, the reason for recall, what the customer should do (dispose of the item, return for refund), and a direct link to request a refund.

11.11 Consumer Protection from Unfair Trading Regulations 2008

The Consumer Protection from Unfair Trading Regulations 2008 (CPRs) prohibit unfair commercial practices, including misleading actions, misleading omissions, aggressive commercial practices, and a blacklist of 31 specific practices that are always illegal. For a grocery e-commerce platform, the most relevant provisions concern accurate pricing, honest product descriptions, transparent discount claims, and non-aggressive sales tactics.

Legal Requirements

- **No misleading actions:** You must not provide false or deceptive information about the product, price, availability, or any other material factor that would influence a consumer's purchasing decision.
- **No misleading omissions:** You must not omit material information that a consumer would need to make an informed decision. This includes hiding delivery fees, not disclosing out-of-stock status, or failing to mention that a "discount" is based on an artificially inflated reference price.
- **Genuine discount claims:** If you display a "was" price alongside a "now" price, the "was" price must be a genuine previous selling price that was available for a meaningful period (typically 28 consecutive days in the previous 6 months). The ASA (Advertising Standards Authority) enforces this rigorously.
- **No bait advertising:** You must not advertise products at a promotional price if you know or should know that you will not be able to supply them at that price in sufficient quantities.
- **No pressure selling:** You must not use aggressive tactics such as fake countdown timers, false scarcity claims ("Only 2 left!" when stock is high), or auto-renewing subscriptions without clear disclosure.

How We Will Comply

- **Accurate "Was" Price Display:** The products table includes both price and compare_at_price columns. The compare_at_price field must only be populated with a genuine previous selling price. In the admin product form, add a validation rule: if compare_at_price is set, it must be greater than the current price, and a tooltip must explain: "This must be a genuine price at which the product was sold for at least 28 consecutive days in the previous 6 months." Display the "was" price with a strikethrough and the percentage discount calculated server-side.
- **Real-Time Stock Display:** Never display "Only X left!" unless the stock count is genuinely low (below the low_stock_threshold). The product card shows an "In Stock" badge when stock_count is above the threshold and a "Low Stock" badge when below. When stock reaches 0, the "Add" button changes to "Out of Stock" and is disabled. This prevents misleading scarcity claims.
- **Transparent Pricing (No Hidden Fees):** All prices displayed on product cards, the product detail page, and the cart are inclusive of VAT. The delivery fee is displayed on the cart sidebar before the customer reaches the checkout page. The total shown at checkout is the final amount charged, with no additional fees added after payment confirmation.
- **Honest Product Images:** Product images must accurately represent the actual product. Do not use enhanced or misleading images that exaggerate size, quality, or quantity. If an image shows multiple items (e.g., a pack of 6), the product description must clearly state the pack size.
- **Promo Code Honesty:** Promo codes must work as advertised. The promo_codes table includes discount_type and discount_value fields that are applied server-side. If a code is advertised as "10% off", the discount calculation must use the exact percentage, not a rounded-down amount. Display the discount applied clearly in the cart summary and on the receipt.

11.12 Privacy and Electronic Communications Regulations (PECR)

The Privacy and Electronic Communications Regulations 2003 (PECR) sit alongside the Data Protection Act and UK GDPR, providing specific rules for electronic communications. For your platform, the most relevant

provisions cover the use of cookies, direct marketing by email and SMS, and the security of communications. PECR is enforced by the ICO and breaches can result in fines of up to 500,000 GBP.

Legal Requirements

- **Cookie consent:** You must obtain informed consent before storing or accessing non-essential cookies on a user's device. Essential cookies (session ID, shopping cart, security tokens) do not require consent. Analytics, advertising, and social media cookies do require consent.
- **Email marketing consent:** You must not send marketing emails to individuals without their specific consent (opt-in). The only exception is the "soft opt-in" for existing customers: if a customer bought something from you, you can email them about similar products, but you must give them an easy way to opt out in every email.
- **SMS marketing consent:** SMS marketing always requires explicit prior consent (opt-in). There is no "soft opt-in" exception for SMS. You must not send promotional SMS messages to customers who have not explicitly opted in.
- **Unsubscribe mechanism:** Every marketing email must include a working unsubscribe link. Every marketing SMS must include an opt-out instruction (e.g., "Reply STOP to unsubscribe"). Unsubscribe requests must be processed within 24 hours.
- **Caller ID:** If you make any phone calls to customers, you must not withhold your telephone number.

How We Will Comply

- **Cookie Consent Implementation:** Use a GDPR/PECR-compliant cookie consent management tool (Cookiebot, OneTrust, or Osano). The consent banner must: appear on first visit, before any non-essential cookies are set, provide granular categories (Essential, Analytics, Marketing), allow accept-all or reject-all with equal prominence, store consent preferences with a timestamp, and allow users to change preferences at any time via a floating "Cookie Settings" icon in the footer. Block all third-party scripts (Google Analytics, Facebook Pixel) until consent is given.
- **Marketing Consent at Registration:** The customer registration form must include separate opt-in checkboxes for: email marketing ("I would like to receive offers and updates by email") and SMS marketing ("I would like to receive delivery updates and offers by SMS"). Both checkboxes must be unchecked by default (no pre-ticked

boxes). Store consent in the users table with columns: email_marketing_consent (BOOLEAN), sms_marketing_consent (BOOLEAN), and marketing_consent_date (TEXT).

- **Soft Opt-In for Transactional Emails:** Customers who place an order can receive emails about similar products without explicit marketing consent (soft opt-in). However, every such email must include an unsubscribe link and a clear statement: "You are receiving this because you recently ordered from us." Use Resend's unsubscribe management feature.
- **Unsubscribe Handling:** Build an /unsubscribe API endpoint that accepts an email parameter, sets email_marketing_consent = FALSE in the users table, logs the unsubscribe event in the audit_log table, and displays a confirmation page. For SMS, use Twilio's built-in STOP keyword handling, which automatically opts the user out of future messages.
- **Transactional vs Marketing Email Separation:** Transactional emails (order confirmation, delivery updates, refund receipts) do not require marketing consent and can always be sent. Marketing emails (promotional offers, new product announcements) require explicit consent. Use separate Resend templates for each category and ensure marketing emails are never sent to users without consent.

11.13 Weights and Measures Act 1985 and Unit Pricing

The Weights and Measures Act 1985 and the Price Marking Order 2004 require that goods sold to consumers must be accurately measured and that unit pricing must be displayed for products sold by weight or volume. Unit pricing (e.g., "1.20 GBP per 100g" or "0.80 GBP per litre") allows consumers to compare the value of different products and different pack sizes. Trading Standards officers actively enforce unit pricing requirements, and non-compliance can result in improvement notices and prosecution.

Legal Requirements

- **Accurate weights and measures:** The quantity of goods supplied must match the stated quantity. A pack labelled as 500g must contain at least 500g (within the tolerances allowed by the Average Quantity System).
- **Unit pricing:** Products sold by weight or volume must display the unit price (price per kilogram, per 100 grams, per litre, or per 100 millilitres) alongside the selling price. This is mandatory for products

above 10g/10ml sold in pre-packaged quantities.

- **Price marking:** The selling price must be clearly displayed on or near the product. For online sales, the price must be visible on the product listing and the product detail page.

How We Will Comply

- **Unit Price Database Column:** The products table already includes a `unit_price` column (TEXT, e.g., "1.20/100g"). This field is mandatory for all products with `weight_value` and `weight_unit` populated. The admin product form auto-calculates the unit price from the selling price and the weight/volume, using the formula: $\text{unit_price} = (\text{price} / \text{weight_value}) * 100$ for per-100g/per-100ml display. The Manager can override the auto-calculated value if needed.
- **Unit Price Display on Product Cards:** Every product card on the homepage sliders and category pages must display the unit price below the selling price, e.g., "3.50 GBP (1.40 GBP/100g)". This allows customers to compare value at a glance without clicking into the detail page.
- **Unit Price Display on Product Detail Page:** The product detail page must display the selling price prominently, followed by the unit price in a smaller font directly below. The format must follow Trading Standards guidance: use the appropriate unit (per kg, per 100g, per L, per 100ml) based on the product type.
- **Weight/Volume Validation:** The admin product form validates that `weight_value` is a positive number and that `weight_unit` is one of the allowed values (g, kg, ml, L). If either field is empty, the product cannot be set to `is_active = TRUE`. This ensures that unit pricing can always be calculated for active products.

11.14 Digital Markets, Competition and Consumers Act 2024

The Digital Markets, Competition and Consumers Act 2024 (DMCCA) received Royal Assent in May 2024 and is being implemented in stages. It significantly strengthens consumer protection law, including new rules on subscription contracts, fake reviews, drip pricing, and enforcement powers for the CMA (Competition and Markets Authority). While the full secondary legislation is still being developed, the Act introduces direct enforcement powers that allow the CMA to impose fines of up to 10% of global turnover without going to court. For a grocery delivery platform, the most relevant provisions are drip pricing (adding mandatory fees late

in the checkout process), subscription transparency, and fake review prevention.

Legal Requirements

- **No drip pricing:** You must not add mandatory charges incrementally during the checkout process (drip pricing). All mandatory fees must be included in the upfront price or clearly disclosed before the customer begins the checkout process.
- **Subscription transparency:** If offering any subscription service (e.g., a monthly delivery pass), you must clearly disclose: the total cost, the billing frequency, how to cancel, and a cooling-off period. Auto-renewal must be clearly communicated.
- **No fake reviews:** You must not submit or commission fake reviews, and you must take reasonable steps to prevent fake reviews from appearing on your platform. If you implement a product review or rating feature, it must be genuine and verifiable.
- **CMA direct enforcement:** The CMA can now investigate and fine companies directly without going through courts. This means faster enforcement and higher penalties for non-compliance.

How We Will Comply

- **Upfront Fee Disclosure:** Display the delivery fee on the cart sidebar before the customer enters the checkout flow. The checkout page shows a complete price breakdown: item total, delivery fee, discount (if any), VAT breakdown, and final total. No fees are added after the customer clicks "Place Order". If a delivery surcharge applies for certain postcodes, it is displayed when the customer enters their postcode, not at the payment step.
- **No Mandatory Add-Ons:** Do not add optional services (gift wrapping, bag fee, insurance) as pre-ticked boxes at checkout. Any optional extras must be unchecked by default and clearly labelled as optional. This prevents "dark patterns" that the DMCCA specifically targets.
- **Review Integrity:** If implementing product ratings or reviews, ensure that: only verified purchasers (customers who have actually bought the item) can leave a review, reviews cannot be edited or deleted by the business after submission, and the average rating is calculated accurately. The star rating displayed on product cards must reflect genuine customer feedback.
- **Subscription Features (Future):** If implementing a delivery subscription (e.g., "Unlimited free delivery for 9.99 GBP/month"),

ensure: the subscription sign-up page clearly states the monthly cost, the minimum term (if any), how to cancel (with a direct link), and that cancellation takes effect at the end of the current billing period. Send a reminder email 7 days before each renewal. Store subscription consent in the users table.

11.15 Compliance Implementation Summary

The following table provides a consolidated view of all UK regulations covered in this section, mapping each law to the specific platform features and implementation measures that ensure compliance. Use this table as a quick reference during development and compliance reviews.

Regulation	Key Requirement	Platform Feature / Implementation
UK GDPR / DPA 2018	Lawful basis, data minimisation, SARs, breach notification	ICO registration, privacy policy, cookie consent, SAR handler, data erasure, DPIA, DPAs with processors, staff training
Consumer Rights Act 2015	Satisfactory quality, fit for purpose, 30-day right to reject	Accurate descriptions, Picker QA checklist, refund workflow, 30-day guarantee statement, delivery performance tracking
Consumer Contracts Regs 2013	Pre-contract info, 14-day cancellation, no hidden charges	Order summary at checkout, cancellation policy page, perishable/non-perishable classification, in-app cancel button, transparent pricing, order confirmation email
Food Info Regs 2014 (FIC)	Allergen emphasis, ingredients, use-by dates, Natasha's Law	Allergen badges, bold allergen emphasis in ingredients, allergen filter, use-by date display, auto-deactivation cron, PPDS label support
Challenge 25 / Licensing Act 2003	Age verification for alcohol, premises licence, personal licence	challenge_25 flag, checkout age confirmation, "18+" badge, Rider verification screen, licence documentation, staff training records
Equality Act 2010	Reasonable adjustments, WCAG 2.1 AA	Keyboard navigation, screen reader support, colour contrast testing, accessibility statement page, axe-core CI testing

VAT Act 1994 / HMRC	Correct VAT rates, VAT-inclusive pricing, MTD	vat_rate per product, server-side calculation, VAT receipt breakdown, VAT finance report, CSV export for MTD
E-Commerce Regs 2002	Service provider info, contract formation, T&Cs;	Footer company info, T&Cs; page with acceptance, order review step, order acknowledgement email, commercial comms labelling
Payment Services Regs 2017	Strong Customer Authentication (3DS)	Stripe 3DS automatic mode, PaymentIntent flow, chargeback handling, refund process
Food Safety Act 1990	HACCP, temperature control, traceability, recall	HACCP plan document, temperature logging, use-by date cron, hygiene rating display, wastage_log, product recall admin feature
Consumer Protection Regs 2008	No misleading actions, genuine discounts, no bait advertising	compare_at_price validation, real-time stock display, transparent pricing, honest product images, honest promo codes
PECR 2003	Cookie consent, email/SMS marketing consent, unsubscribe	Cookie consent banner, marketing opt-in checkboxes, soft opt-in for existing customers, unsubscribe endpoint, STOP keyword for SMS
Weights and Measures Act 1985	Unit pricing, accurate weights, price marking	unit_price column, auto-calculation, unit price on cards and detail pages, weight/volume validation
DMCCA 2024	No drip pricing, subscription transparency, no fake reviews	Upfront fee disclosure, no pre-ticked add-ons, verified-only reviews, subscription transparency (future)

Table 17: UK regulatory compliance implementation summary

Important: This section provides guidance based on UK law as of 2025. Regulations change frequently. Before launch, have a solicitor review your platform against the current versions of all regulations listed above. Subscribe to ICO guidance updates (ico.org.uk), FSA alerts (food.gov.uk), and Trading Standards bulletins (tradingstandards.uk) for ongoing compliance monitoring.

12. Development Plan

The 8-week development plan below provides a realistic timeline with compliance checkpoints and testing gates. Each phase must pass its milestone before the next phase begins. The visual timeline shows the phases, deliverables, and key milestones at a glance.

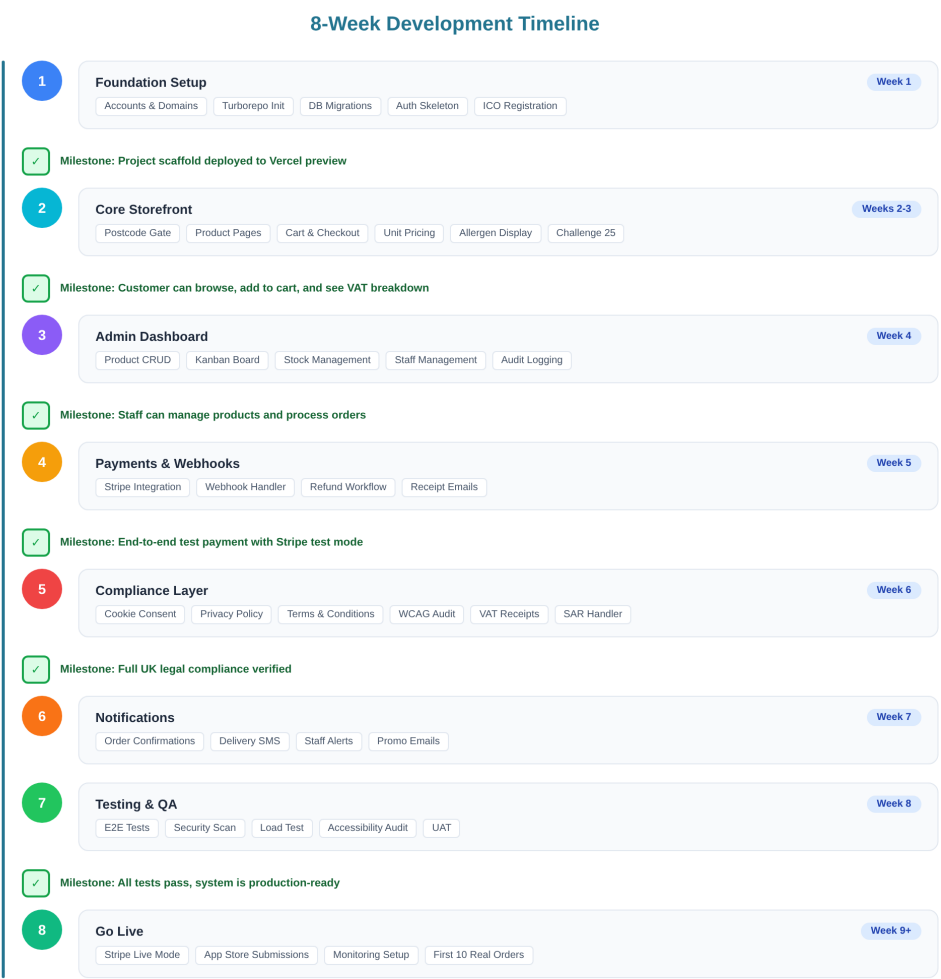


Figure 5: 8-week development timeline with milestones

12.1 Phase Details

Phase	Duratio n	Goal	Key Deliverables
-------	--------------	------	------------------

Phase 1: Foundation	Week 1	Accounts, project setup, database schema	Monorepo, DB migrations, auth skeleton
Phase 2: Storefront	Weeks 2-3	Customer shopping experience	Postcode gate, products, cart, checkout
Phase 3: Admin	Week 4	Store management and fulfilment	Product CRUD, Kanban, staff management
Phase 4: Payments	Week 5	Stripe integration and webhooks	Payment flow, webhook handler, receipts
Phase 5: Compliance	Week 6	UK legal and accessibility	VAT, privacy, WCAG, cookie consent
Phase 6: Not ifications	Week 7	Customer and staff communication	Email, SMS, admin alerts
Phase 7: Testing	Week 8	Comprehensive QA	E2E tests, security audit, UAT
Phase 8: Launch	Week 9+	Go live and monitor	Live Stripe, app stores, monitoring

Table 18: Development plan overview

12.2 Phase 1: Foundation (Week 1)

Day 1-2: Account Setup

- Register UK domain name (e.g., towndelivery.co.uk)
- Create GitHub organisation with branch protection rules
- Set up Vercel project with preview deployments
- Create Turso database and obtain connection string
- Register with ICO as a data controller
- Create Stripe account in UK mode

Day 3-4: Project Initialisation

- Initialise Turborepo monorepo with apps/web and apps/admin
- Configure shared packages: UI components, database client, types
- Set up Drizzle ORM with Turso driver; write initial migration for all tables
- Configure NextAuth.js v5 with credentials provider and magic link
- Set up ESLint, Prettier, and Husky pre-commit hooks

Day 5-7: Database and Auth

- **Run database migrations and seed with sample product data**
- **Implement user registration and login API routes**
- **Implement RBAC middleware for admin route protection**
- **Set up Vercel KV for session storage and rate limiting**
- **Write API integration tests for auth endpoints**
- **Deploy to Vercel preview and verify all services connect**

12.3 Phase 2: Core Storefront (Weeks 2-3)

Week 2: Browsing and Discovery

- **Implement postcode gate with Postcodes.io API validation**
- **Build sticky header with search bar, location picker, and cart widget**
- **Create category slider and product card components with unit pricing**
- **Build homepage banner carousel with admin-configurable slides**
- **Implement category listing page with left sidebar and product grid**
- **Add Challenge 25 badge rendering for age-restricted products**
- **Implement allergen information display on product cards and detail pages**

Week 3: Cart, Checkout, and Payment

- **Build slide-out cart sidebar with quantity controls and bill summary**
- **Implement server-side cart validation (stock check, price verification)**
- **Build checkout form with address auto-complete using postcode lookup**
- **Display VAT breakdown on receipt (0%, 5%, 20% line items)**
- **Implement Stripe PaymentIntent creation on the server**
- **Build order confirmation page with estimated delivery time**
- **Add guest checkout flow with email-only identification**

12.4 Phase 3: Admin Dashboard (Week 4)

- **Build admin layout with sidebar navigation and role-based menu visibility**
- **Implement product CRUD with image upload, VAT selector, and Challenge 25 toggle**
- **Build Kanban board with real-time order status updates (5-second polling)**
- **Implement stock management with kill switch and low-stock alerts**

- **Build employee management with attendance tracking and daily performance**
- **Implement category and brand management interfaces**
- **Add audit log viewer for Owner role**
- **Build promo code management with usage restrictions and expiry dates**

12.5 Phase 4: Payments and Webhooks (Week 5)

- **Implement Stripe webhook handler with signature verification**
- **Handle payment_intent.succeeded: mark order "Paid", decrement inventory**
- **Handle payment_intent.failed: mark order "Abandoned", restore inventory**
- **Handle charge.refunded: update order status, log refund reason**
- **Implement idempotent webhook processing (prevent duplicate updates)**
- **Build refund initiation from admin panel (Manager+ role only)**
- **Set up Stripe test mode and create test scenario scripts**
- **Implement receipt email sending via Resend on successful payment**

12.6 Phase 5: Compliance Layer (Week 6)

- **Implement cookie consent banner with granular preference controls**
- **Create privacy policy page and terms and conditions page**
- **Build cancellation and returns information page**
- **Implement VAT receipt generation with HMRC-compliant format**
- **Verify unit pricing display on all product pages**
- **Ensure Challenge 25 age verification prompt at checkout**
- **Conduct WCAG 2.1 AA accessibility audit**
- **Add allergen filtering and prominent allergen display**
- **Implement data export for Subject Access Requests**

12.7 Phase 6: Notifications (Week 7)

- **Set up Resend for transactional emails (confirmation, receipt, delivery update)**
- **Set up Twilio for SMS notifications (delivery ETA, rider assignment)**
- **Build in-app notification centre in admin dashboard**
- **Implement new order alert with sound notification for staff**

- **Add order status change notifications to customer**
- **Implement delivery ETA SMS with tracking link**

12.8 Phase 7: Testing and QA (Week 8)

- **Write end-to-end tests with Playwright for all critical user journeys**
- **Verify VAT calculations: 0% on fresh food, 20% on alcohol and soft drinks**
- **Test Challenge 25 flow: age-restricted items prompt verification**
- **Test RBAC: Picker cannot access Finance; Rider cannot modify products**
- **Load test with k6: simulate 100 concurrent users**
- **Security scan with OWASP ZAP: SQL injection, XSS, CSRF**
- **Accessibility audit with axe-core and manual screen reader testing**
- **Mobile device testing on iOS Safari and Android Chrome**
- **Stripe webhook testing with all event types**
- **User acceptance testing with store owner and staff**

12.9 Phase 8: Launch (Week 9+)

- **Switch Stripe from test mode to live mode with real bank account**
- **Deploy production build to Vercel and verify all services**
- **Submit Android app to Google Play Console (Physical Goods exemption)**
- **Submit iOS app to App Store Connect (Physical Goods exemption)**
- **Set up Sentry error monitoring with Slack/email alerts**
- **Configure Vercel Analytics for Core Web Vitals monitoring**
- **Monitor first 20 orders closely and resolve issues immediately**

13. Notification System

A grocery delivery service lives and dies by its communication. Customers need real-time updates on their order, and staff need alerts when new orders arrive or issues arise. The notification system uses Resend for transactional emails, Twilio for SMS, and in-app push for the admin dashboard.

Event	Channel	Recipient	Content
-------	---------	-----------	---------

Order confirmed	Email + In-app	Customer	Order summary, ETA, receipt with VAT breakdown
Payment successful	Email	Customer	Payment receipt from Stripe
Order packing started	In-app + SMS	Customer	Status update with revised ETA
Order out for delivery	Push + SMS	Customer	Rider name, ETA countdown, tracking link
Rider sets ETA	Push + SMS	Customer	Your order arrives in XX min (countdown starts)
ETA adjusted by rider	Push + SMS	Customer	Updated delivery time: XX min
Rider arriving (ETA < 5 min)	Push + SMS	Customer	Your rider is almost there!
Order delivered	Email + SMS + Push	Customer	Delivery confirmation, feedback prompt
New order received	Push + Sound	Staff (Pickers)	Order details, items to pack
Order assigned to rider	Push + Sound	Staff (Rider)	Delivery address, postcode map, customer phone
Delivery assigned (Rider app)	Push (high priority)	Staff (Rider)	New delivery! Tap to view order + set ETA
ETA expired (late delivery)	In-app	Manager	Order #X is past its ETA. Check with rider.
Age verification failed	Push	Customer + Manager	Restricted items removed, partial refund initiated
Low stock alert	In-app	Manager	Product name, current stock, threshold
Payment failed	Email	Customer	Reason, retry link, cart preserved

Table 19: Complete notification matrix

14. Security Framework

14.1 Data Protection

- All PII (names, addresses, phone numbers) encrypted at rest using AES-256
- Payment card data never touches your server; handled entirely by Stripe Elements
- Database backups encrypted and stored in a separate region
- Data retention: order data 7 years (HMRC), PII deleted 30 days after account closure
- Automated daily backups via Turso scheduled backups

14.2 Infrastructure Security

- HTTPS enforced on all routes (Vercel default)
- Content Security Policy header preventing inline script execution
- Environment variables for all secrets (never commit .env files)
- Vercel deployment protection: preview deployments require password
- Database connection over TLS only
- Regular dependency audit with npm audit and Snyk

14.3 Incident Response

Incident	Detection	Response	Recovery
Payment failure spike	Sentry alert + Stripe dashboard	Check Stripe status; manual payment recording	Reprocess failed payments when Stripe recovers
Database outage	Sentry alert + Vercel logs	Switch to read-only mode with cached data	Restore from Turso backup; verify data integrity
Security breach	Sentry anomaly + manual report	Rotate all API keys; force staff password reset	Notify ICO within 72 hours if personal data affected
Delivery zone failure	Customer complaints + monitoring	Display maintenance banner; disable checkout	Revalidate postcode database; resume service

Table 20: Incident response runbook

15. Golden Rules

Rule 1: Never Calculate Prices in the Browser

The browser is an untrusted environment. A technically skilled customer can modify any JavaScript variable, including prices, quantities, and VAT rates. All price calculations must happen on the server (your Vercel API routes), and the server must revalidate every order by looking up current prices from the database before creating a Stripe `PaymentIntent`. The client should only send product IDs and quantities; the server fills in prices, calculates VAT, and determines the total.

Rule 2: The Webhook is the Boss

Your admin app should never talk to Stripe directly. It should only read the database. When a customer pays, Stripe sends a webhook to your API route. Your API verifies the webhook signature (using your Stripe webhook secret), updates the database to mark the order as "Paid", and decrements inventory. The admin dashboard polls the database for changes. This ensures that your system of record is always the database, not Stripe's dashboard.

Rule 3: Start Free, Scale Smart

Vercel, Turso, and Resend have generous free tiers that can handle hundreds of orders per month. Use them until your revenue justifies paid plans. Vercel Pro at approximately 20 GBP per month is the first upgrade you will need. Turso Scaler at approximately 29 GBP per month becomes necessary when you need more than the free database limits.

Rule 4: Compliance is Not Optional

Every feature you build must be checked against UK law. Before launching any new page or feature, ask: "Does this comply with UK GDPR? The Consumer Rights Act? The Consumer Contracts Regulations? Food Information Regulations?" If you are unsure, consult a solicitor. Make compliance checks a mandatory part of your code review process.

Rule 5: Test in Production Conditions

Testing with Stripe's test cards is necessary but not sufficient. Before going live, have friends and family place real orders with real payment cards, process real refunds, and test the delivery flow end-to-end. Only when you have successfully completed 10 real orders without any errors should you consider the system production-ready.

Rule 6: Every Data Change is Audited

Every modification to orders, products, user data, and financial records must be logged in the `audit_log` table with the user ID, action, timestamp, and before/after values. This protects you in disputes, supports HMRC compliance, and provides a forensic trail if something goes wrong.

16. Final Checklist

Every item must be verified before launch. Items marked with an asterisk (*) are legal requirements; failure to comply can result in fines or prosecution.

Category	Item	Status
Setup	UK domain purchased and connected to Vercel	[]
Setup	GitHub repository with branch protection rules	[]
Setup	Vercel project with preview deployments enabled	[]
Setup	Turso database with all tables migrated	[]
Setup	Stripe account verified in UK mode	[]
Setup	ICO registration completed *	[]
Database	VAT rates configured per product category *	[]
Database	Unit pricing populated for all products *	[]
Database	Challenge 25 flags set on alcohol/energy drinks *	[]
Database	Allergen data entered for all applicable products *	[]
Storefront	Postcode gate validates delivery zone	[]
Storefront	UK Unit Pricing displayed on all product cards *	[]
Storefront	VAT breakdown shown on checkout receipt *	[]
Storefront	Challenge 25 age prompt at checkout *	[]

Storefront	Privacy policy page published *	[]
Storefront	Terms and conditions page published *	[]
Storefront	Cookie consent banner implemented *	[]
Storefront	Cancellation rights displayed at checkout *	[]
Storefront	WCAG 2.1 AA accessibility verified	[]
Admin	Product CRUD with image upload working	[]
Admin	Kanban board updates in real-time on payment	[]
Admin	Stock management with kill switch functional	[]
Admin	RBAC enforced: Picker/Rider restricted views	[]
Admin	Audit log recording all data modifications	[]
Payments	Stripe webhook active and signature verified	[]
Payments	Refund workflow functional from admin panel	[]
Payments	Receipt emails sent on successful payment	[]
Notifications	Order confirmation email delivered	[]
Notifications	Delivery SMS with tracking link working	[]
Notifications	Staff new order alert with sound working	[]
Tracking	Rider can set manual ETA (15/30/45/60 min presets)	[]
Tracking	Customer sees live countdown timer on order tracking screen	[]
Tracking	Rider "+10 min" ETA adjustment works (max 3 adjustments)	[]
Tracking	Customer receives push notification on ETA change	[]
Tracking	Rider can mark order as delivered from mobile	[]

Tracking	Challenge 25 "Cannot Verify" triggers partial refund	[]
Tracking	ETA expiry auto-alerts Manager in admin dashboard	[]
Security	Rate limiting on all API endpoints	[]
Security	CSRF protection on state-changing endpoints	[]
Security	Security headers (HSTS, CSP, X-Frame-Options)	[]
Security	Daily database backups verified	[]
Mobile	Android build uploaded to Google Play	[]
Mobile	iOS build uploaded to App Store Connect	[]
Mobile	Physical Goods exemption selected in both stores	[]
Mobile	Push notifications working on iOS and Android	[]
Mobile	Rider app distributed via internal testing tracks	[]
Mobile	Biometric login (Face ID / fingerprint) working	[]
Mobile	Offline cart and order tracking tested on both platforms	[]
Mobile	Rider ETA setting screen tested on real devices	[]
Launch	Stripe switched to live mode	[]
Launch	Sentry error monitoring configured	[]
Launch	First 10 real orders completed without errors	[]

Table 21: Pre-launch checklist (* = legal requirement)

17. Cost Estimation

17.1 Development Costs (One-Time)

Item	Cost (GBP)	Notes
UK domain name	10-15/year	e.g. towndelivery.co.uk via 123-Reg
ICO registration	40/year	Data controller fee for small business
Google Play Developer	25 (one-time)	Android app publishing fee

Apple Developer Program	99/year	iOS app publishing fee
SSL certificate	0	Included with Vercel hosting
Total one-time setup	174-184	First year total including annual fees

Table 22: One-time development costs

17.2 Monthly Operational Costs

Service	Free Tier	Pro Tier (GB P/month)	Trigger for Upgrade
Vercel Hosting	Hobby (free)	20	Team features, longer timeouts
Turso Database	Starter (free)	29	More storage, more replicas
Stripe Payments	No monthly fee	N/A	1.5% + 20p per UK card transaction
Resend (Email)	100 emails/day free	15	More emails, custom domain
Twilio (SMS)	Pay per message	~20	3-5p per UK SMS; 500-1000 orders/month
Vercel KV (Cache)	30 commands/min free	10	More commands, persistence
Sentry (Monitoring)	5K errors/month free	19	More events, team features
Total (Free Tier)	0/month		Sufficient for first 100-200 orders/month
Total (Pro Tier)		113/month	Needed for 500+ orders/month

Table 23: Monthly operational costs by tier